

TokTickIT Lab 3 Final Submission

Rubric-aligned evidence package

Author: Chartanat Upthaipiboon | Student ID: 67070507210

Repository: Chxtamos/-TokTickIT- | Verified released main before this evidence-only update:
319c34c3d23a86fa6a28ef74d7f9d8e11f1a6de6

[Repository](#)

[GitHub Project / Kanban](#)

This PDF follows the Lab 3 handout order exactly: Answer Part 1 through Answer Part 9. UI screenshots are intentionally enlarged; long full-page captures are cropped to readable evidence regions rather than reduced into unreadable contact sheets.

Answer Part 1: Git Use with Engineering Workflow

Workflow evidence: feature/documentation branches were reviewed into lab3-staging, then release PRs promoted staging to main. PR #89 is the final documentation release currently on main.

[PR #68](#)

[PR #69](#)

[PR #70](#)

[PR #71](#)

[PR #72](#)

[PR #74](#)

[PR #76](#)

[PR #77](#)

[PR #78](#)

[PR #79](#)

[PR #80](#)

[PR #81](#)

[PR #82](#)

[PR #84](#)

[PR #86](#)

[PR #87](#)

[PR #88](#)

[PR #89](#)

Final Project/Kanban status: Issue #65 and release PR #89 were verified Done after merge. Earlier implementation Issues were completed through their merged feature PRs.

Recent merge history

```
737f119 (HEAD -> docs/40-lab3-rubric-final-pdf, origin/lab3-staging, lab3-staging) Merge pull request #88 from Chxtamos/fix/39-lab3-final-do
c03494c Merge pull request #86 from Chxtamos/docs/38-lab3-final-submission
55d80fe Merge pull request #84 from Chxtamos/lab3-staging
aa45eb7 Merge pull request #85 from Chxtamos/fix/37-lab3-release-evidence
3bcb4a9 Merge pull request #82 from Chxtamos/feature/35-lab3-admin-user-management
9cfa1cf Merge pull request #81 from Chxtamos/feature/34-lab3-staff-detail-ui
43284bc Merge pull request #80 from Chxtamos/feature/33-lab3-comments-notes-api
2837a43 Merge pull request #79 from Chxtamos/feature/32-lab3-workflow-api
df20557 Merge pull request #78 from Chxtamos/feature/31-lab3-operational-ticket-detail
4b87880 Merge pull request #77 from Chxtamos/feature/30-lab3-staff-queue
3c64e45 Merge pull request #76 from Chxtamos/feature/29-lab3-authenticated-requester
cd363b4 Merge origin/lab3-staging into Issue 56 branch
e62e4c5 Merge pull request #74 from Chxtamos/docs/29-lab3-issue-consolidation
07c7a75 Merge pull request #72 from Chxtamos/feature/28-lab3-requester-authorization
74586fc Merge pull request #71 from Chxtamos/feature/27-lab3-auth-sessions
5819368 Merge pull request #70 from Chxtamos/feature/26-lab3-user-migration-seed
d6be2e5 Merge pull request #69 from Chxtamos/feature/25-lab3-test-isolation-ci
ca60016 Merge pull request #68 from Chxtamos/feature/24-lab3-engineering-contract
```

Rendered reviewer.md - identity and review evidence

Full source: docs/lab-03/reviewer.md

Author and reviewer

- **Author:** Chartanat Uthaipliboon
- **Author student ID:** 67070507210
- **Author GitHub:** Chxtamos (<https://github.com/Chxtamos>)
- **Primary peer reviewer:** Tanaboonnnnn (<https://github.com/Tanaboonnnnn>)
- **Peer reviewer name:** Tanboon Teawsawat
- **Peer reviewer student ID:** 67070507211

The reviewer identity matches the student-confirmed Lab 2 repository record in docs/lab-02/reviewer.md. PR #68 has four Changes Requested reviews and a final APPROVED review, recorded below.

Rendered reviewer.md - implementation/release log excerpt

Includes reviewer identity, reviewed heads, requested-change responses, approvals, CI and merge evidence.

Implementation and release log

Create one row per real PR as work proceeds. Required fields: Issue/PR URL, feature branch/base, reviewed head commit, reviewer identity, substantive comments, response/correction commit, approval URL, check/test evidence, merge commit/date.

Final release targets main from lab3-staging; record final main verification revision/results in tests.md.

PR	Branch/base and reviewed head	Reviewer/review response	Approval	CI evidence	Merge
#69	(https://github.com/Chxtamos/-TokTickIT-/pull/69)	feature/25-lab3-test-isolation-ci -> lab3-staging, 38d4e46	Tanaboonnann requested		
#70	(https://github.com/Chxtamos/-TokTickIT-/pull/70)	feature/26-lab3-user-migration-seed -> lab3-staging, db69ab3	Peepipat-Suesoongnuen		
#71	(https://github.com/Chxtamos/-TokTickIT-/pull/71)	feature/27-lab3-auth-sessions -> lab3-staging, cc0c743	chaproi requested changes		
#72	(https://github.com/Chxtamos/-TokTickIT-/pull/72)	feature/28-lab3-requester-authorization -> lab3-staging, 3a28e39	Peepipat-Suesoongnuen		
#74	(https://github.com/Chxtamos/-TokTickIT-/pull/74)	docs/29-lab3-issue-consolidation -> lab3-staging, final reviewed head d132841	com		
#76	(https://github.com/Chxtamos/-TokTickIT-/pull/76)	feature/29-lab3-authenticated-requester -> lab3-staging, final reviewed head a6905			
#77	(https://github.com/Chxtamos/-TokTickIT-/pull/77)	feature/30-lab3-staff-queue -> lab3-staging, reviewed head 6cb6a89	Staff Queue A		
#78	(https://github.com/Chxtamos/-TokTickIT-/pull/78)	feature/31-lab3-operational-ticket-detail -> lab3-staging, reviewed head e2f5730			
#79	(https://github.com/Chxtamos/-TokTickIT-/pull/79)	feature/32-lab3-workflow-api -> lab3-staging, reviewed head fbc2e8c	Ownership/pr		
#80	(https://github.com/Chxtamos/-TokTickIT-/pull/80)	feature/33-lab3-comments-notes-api -> lab3-staging, reviewed head 368de64	Public		
#81	(https://github.com/Chxtamos/-TokTickIT-/pull/81)	feature/34-lab3-staff-detail-ui -> lab3-staging, reviewed head 1a09fb1	Integrated		
#82	(https://github.com/Chxtamos/-TokTickIT-/pull/82)	feature/35-lab3-admin-user-management -> lab3-staging, reviewed head ff149aa	Adm		
#84	(https://github.com/Chxtamos/-TokTickIT-/pull/84)	lab3-staging -> main, final reviewed head aa45eb7	Tanaboonnann requested release		
#86	(https://github.com/Chxtamos/-TokTickIT-/pull/86)	docs/38-lab3-final-submission -> lab3-staging, reviewed head 88d00b7	Peepipat-Sue		
#87	(https://github.com/Chxtamos/-TokTickIT-/pull/87)	lab3-staging -> main, reviewed head c03494c	Peepipat-Suesoongnuen reviewed the 5		

README, .gitignore, and repository structure evidence

docs/lab-03/README.md excerpt

Lab 3 Engineering Contract and Release Status

Updated 2026-09-28.

Lab 3 implementation is merged into lab3-staging through PR #82. Issue #65 is the remaining release/evidence issue. The release flow is lab3-staging -> main; Issue #65 must remain open through the merge because its acceptance also requires exact-final-main verification, RELEASE-01 evidence, responsive/accessibility/visual evidence, and the single Part 1-9 PDF.

Documents

```
| File | Purpose |
| --- | --- |
| specification.md (specification.md) | Lab 3 FR/BR/AC contract, authorization/workflow rules, data migration/provisioning and Product DoD |
| api-spec.md (api-spec.md) | Exact endpoints, DTOs, session/cookie/CSRF, errors and concurrency rules |
| ui-spec.md (ui-spec.md) | Role UI, Zen Green, responsive/accessibility and visual evidence contract |
| tests.md (tests.md) | Test traceability, observed CI/local evidence and RELEASE-01 requirements |
| implementation-plan.md (implementation-plan.md) | Historical issue/branch plan and staging flow |
| reviewer.md (reviewer.md) | Peer-review and release record |
| ai-use.md (ai-use.md) | Selected AI prompts and student reflection |
```

Current Runtime Architecture

- Frontend: React 18 + TypeScript + Vite + Bootstrap.
- Backend: Express + TypeScript + Prisma + PostgreSQL.
- Authentication: email/password with opaque database sessions; normal browser identity comes from the authenticated session.
- Roles: REQUESTER, IT_STAFF, ADMINISTRATOR.
- Initial-password sessions are restricted and require password change before normal protected access.
- Browser writes use credentialed CORS, trusted Origin checks and CSRF tokens.
- Requester access is owner-scoped; X-Requester-Id and the Development Requester selector are not runtime identity mechanisms in Lab 3.
- Staff use the shared queue and operational Ticket Detail, claim/assign/reassign, IT Priority, status workflow, Public Comments and Internal Notes.
- Administrators additionally manage user accounts with version, session-revocation, self-deactivation, last-active-admin and owner-cleanup safety.
- Public Comments and Internal Notes are separate; Internal Notes are never exposed to Requesters.

Implementation Line

Lab 3 work merged into lab3-staging through the implementation/review sequence PR #68-#82. This includes test isolation, migration/seed/provisioning, auth/session APIs, authorization/Requester regression, Staff queue/detail/workflow/conversations, integrated Staff UI and Administrator User Management.

The original #51-#67 issue plan remains historical traceability. Consolidated product work #56, #58 and #63 is complete. The only remaining product/release issue is #65 (<https://github.com/Chxtamos/-TokTickIT-/issues/65>).

Current Release State

- lab3-staging contains the full implementation line plus the final-integration fixes/evidence work.
- The release PR must use **head lab3-staging** and **base main**.
- The release PR must reference #65 without automatically closing it.
- Exact-head pre-release Client/Server/E2E CI must be green before merge.
- After merge, rerun affected checks on the exact final main revision, record RELEASE-01/final-main evidence, complete the required responsive/accessibility/visual records, and produce the single Part 1-9 PDF.
- Close #65 only after those post-merge requirements are complete.

Verification Rules

.gitignore excerpt

```

# dependencies
node_modules/
# env & secrets
.env
*.env
!.env.example
# build output
dist/
build/
# prisma
server/prisma/*.db
# logs & OS
*.log
.DS_Store
playwright-report/
test-results/
e2e/.tmp/
.test-storage/

```

Lab 3 repository structure (tracked files excerpt)

```

artifacts/lab-03/TokTickIT_Lab3_Final_Submission.pdf
artifacts/lab-03/ci-visual/1440/01-login.png
artifacts/lab-03/ci-visual/1440/02-requester-my-tickets.png
artifacts/lab-03/ci-visual/1440/03-staff-queue.png
artifacts/lab-03/ci-visual/1440/04-staff-ticket-detail.png
artifacts/lab-03/ci-visual/1440/05-admin-user-management.png
artifacts/lab-03/ci-visual/360/01-login.png
artifacts/lab-03/ci-visual/360/02-requester-my-tickets.png
artifacts/lab-03/ci-visual/360/03-staff-queue.png
artifacts/lab-03/ci-visual/360/04-staff-ticket-detail.png
artifacts/lab-03/ci-visual/390/01-login.png
artifacts/lab-03/ci-visual/390/02-requester-my-tickets.png
artifacts/lab-03/ci-visual/390/03-staff-queue.png
artifacts/lab-03/ci-visual/390/04-staff-ticket-detail.png
artifacts/lab-03/ci-visual/390/05-admin-user-management.png
artifacts/lab-03/ci-visual/768/01-login.png
artifacts/lab-03/ci-visual/zoom-200/01-login.png
artifacts/lab-03/ci-visual/zoom-200/02-requester-my-tickets.png
artifacts/lab-03/ci-visual/zoom-200/03-staff-queue.png
artifacts/lab-03/ci-visual/zoom-200/04-staff-ticket-detail.png
artifacts/lab-03/ci-visual/zoom-200/05-admin-user-management.png
artifacts/lab-03/screenshots/1440/01-login.png
artifacts/lab-03/screenshots/1440/02-requester-my-tickets.png
artifacts/lab-03/screenshots/1440/03-staff-queue.png
artifacts/lab-03/screenshots/1440/04-staff-ticket-detail.png
artifacts/lab-03/screenshots/1440/05-admin-user-management.png
artifacts/lab-03/screenshots/360/01-login.png
artifacts/lab-03/screenshots/360/02-requester-my-tickets.png
artifacts/lab-03/screenshots/360/03-staff-queue.png
artifacts/lab-03/screenshots/360/04-staff-ticket-detail.png
artifacts/lab-03/screenshots/360/05-admin-user-management.png
artifacts/lab-03/screenshots/390/01-login.png
artifacts/lab-03/screenshots/390/02-requester-my-tickets.png
artifacts/lab-03/screenshots/390/03-staff-queue.png
artifacts/lab-03/screenshots/390/04-staff-ticket-detail.png
artifacts/lab-03/screenshots/390/05-admin-user-management.png
artifacts/lab-03/screenshots/768/01-login.png
artifacts/lab-03/screenshots/768/02-requester-my-tickets.png
artifacts/lab-03/screenshots/768/03-staff-queue.png
artifacts/lab-03/screenshots/768/04-staff-ticket-detail.png
artifacts/lab-03/screenshots/768/05-admin-user-management.png
artifacts/lab-03/screenshots/contact-1440.jpg
artifacts/lab-03/screenshots/contact-360.jpg
artifacts/lab-03/screenshots/contact-390.jpg
artifacts/lab-03/screenshots/contact-768.jpg
artifacts/lab-03/screenshots/contact-zoom-200.jpg
artifacts/lab-03/screenshots/zoom-200/01-login.png
artifacts/lab-03/screenshots/zoom-200/02-requester-my-tickets.png
artifacts/lab-03/screenshots/zoom-200/03-staff-queue.png
artifacts/lab-03/screenshots/zoom-200/04-staff-ticket-detail.png
artifacts/lab-03/screenshots/zoom-200/05-admin-user-management.png
client/e2e/lab-03/admin-user-management.spec.ts
client/e2e/lab-03/authentication.spec.ts
client/e2e/lab-03/final-visual-evidence.spec.ts
client/e2e/lab-03/lab3-server-helper.ts
client/e2e/lab-03/requester-auth.ts
client/e2e/lab-03/requester-regression.spec.ts
client/e2e/lab-03/staff-queue.spec.ts
client/e2e/lab-03/staff-ticket-flow.spec.ts
docs/lab-03/README.md
docs/lab-03/ai-use.md
docs/lab-03/api-spec.md
docs/lab-03/final-submission.md
docs/lab-03/implementation-plan.md
docs/lab-03/reviewer.md
docs/lab-03/specification.md
docs/lab-03/tests.md
docs/lab-03/ui-spec.md
server/tests/lab-03/auth.api.test.ts
server/tests/lab-03/auth.postgres.integration.test.ts
server/tests/lab-03/auth.review-regression.api.test.ts

```

server/tests/lab-03/auth.rollback.postgres.integration.test.ts
server/tests/lab-03/authorization.api.test.ts
server/tests/lab-03/comments-notes.api.test.ts
server/tests/lab-03/comments-notes.postgres.integration.test.ts
server/tests/lab-03/conversations.test.ts
server/tests/lab-03/migration.postgres.integration.test.ts
server/tests/lab-03/password.test.ts
server/tests/lab-03/queue-query.test.ts
server/tests/lab-03/seed-provisioning.postgres.integration.test.ts
server/tests/lab-03/staff-queue.api.test.ts
server/tests/lab-03/staff-ticket-detail.api.test.ts
server/tests/lab-03/staff-workflow.postgres.integration.test.ts
server/tests/lab-03/test-database.test.ts
server/tests/lab-03/users-admin.api.test.ts
server/tests/lab-03/users-admin.postgres.integration.test.ts
server/tests/lab-03/workflow.test.ts

Answer Part 2: Spec DD

[Full specification.md](#)

Rendered specification - Sprint Goal and Scope

1. Sprint Goal

Extend the existing Requester MVP with email/password authentication, mandatory initial-password change, backend role/ownership enforcement, an operational IT Staff Ticket Queue and Ticket Detail, shared Public Comments, restricted Internal Notes, and minimalist Administrator User Management. Preserve existing Tickets, Attachments, numbering, reference data, and permitted Requester behavior while replacing the Development Requester selector.

2. Stakeholder Request

Real accounts must replace the temporary requester context. Requesters continue handling their own submissions and communicate with support. IT Staff find, own, prioritize and progress work. Administrators manage accounts. Every screen and API observes the authorization matrix; hidden controls alone never grant protection. All screens extend the existing Zen Green application.

3. Scope

Included: the sprint goal; forward-only Prisma/PostgreSQL migrations and idempotent local seed; all four normative contract documents; traceable tests; Issues, feature PRs, peer review, staged integration, visual evidence and the final nine-part PDF.

Excluded: self-registration; invitations or password-reset email; MFA, social login and SSO; Actions Taken/Service Actions; SLA/escalation/notifications; analytics beyond simple queue totals; organizations/departments/multi-tenancy; multiple roles per user; user deletion, bulk operations, import/export, role/account-history screens, profile pictures, account unlocking or advanced identity management; mandatory admin pagination or multi-column sorting; production deployment/cloud changes. Requester editing/deleting saved Ticket fields is not added: Lab 2 implemented read-only detail and Attachment management.

Rendered specification - numbered Functional Requirements

4. Functional Requirements

- **FR-01:** Authenticate an active, provisioned User using email/password with safe failure feedback and bounded attempts.
- **FR-02:** A successful initial-password login permits only current-user retrieval, mandatory password change and logout before normal application access; its restricted session expires exactly 15 minutes after issuance regardless of activity.
- **FR-03:** Change password after current-password verification and valid new-password confirmation; atomically record passwordChangedAt, increment User.version/updatedAt, revoke old sessions and persist a fresh normal session before its cookie is sent.
- **FR-04:** Restore the session through current-user retrieval; display name/role; logout invalidates server access and clears account-specific UI state.
- **FR-05:** Enforce the matrix in section 5 on the backend and reflect it in navigation, controls and direct screen guards.
- **FR-06:** Replace RequesterUser with User while preserving IDs, activation, Ticket ownership and Attachment removal attribution; remove the selector, Change Requester and requester storage key.
- **FR-07:** Continue Lab 2 create/list/detail, reference data, numbering, idempotency and validation using the authenticated Requester's ID.
- **FR-08:** Preserve owner-only upload/download/soft removal, removed metadata, private file storage and Lab 2 file limits.
- **FR-09:** Requesters read/write Public Comments only on their own Tickets and indicate that a problem appears resolved without changing status.
- **FR-10:** IT Staff retrieve a shared queue with search, filters, deterministic sorting and pagination defined in api-spec.md.
- **FR-11:** IT Staff open Ticket Detail with submitted information, requester, ownership, both priorities, status, Attachments and role-permitted conversations.
- **FR-12:** Claim, assign or reassign one primary Ticket Owner using validated active eligible accounts and concurrency checks; retain owner-change provenance when ownership changes or an account loses eligibility. Staff manual unassign is excluded from Lab 3.
- **FR-13:** Initialize IT Priority from Requested Priority and permit operational updates without changing the submitted Requested Priority.
- **FR-14:** Enforce all eight statuses and the transition matrix, resolution requirements, confirmation and stale-write behavior.
- **FR-15:** Retrieve/create Public Comments with backend author/time, plain-text rendering and append-only semantics.

- **FR-16:** Retrieve/create Internal Notes for operational roles only; prevent note content/metadata/counts from Requester responses.
- **FR-17:** Administrators list users, search name/email, optionally filter one role, and create accounts with one role and initial password.
- **FR-18:** Administrators edit name/email/role/activation, prevent duplicates and protect self/last-active-Administrator safety.
- **FR-19:** Administrators set a new initial password; invalidate the target's sessions and require password change at next login.
- **FR-20:** Deactivation or role/account changes invalidate affected sessions; losing owner eligibility safely unassigns affected Tickets.
- **FR-21:** Extend the existing Zen Green tokens, reusable controls, badges and shell across desktop/tablet/mobile with keyboard and accessible feedback.
- **FR-22:** Provide relevant loading, saving, validation, success, empty/no-results, forbidden, not-found, conflict and safe failure feedback.
- **FR-23:** Provision migrated accounts safely, seed required roles/workflow examples repeatedly without resetting existing credentials or work.
- **FR-24:** Create the test plan before implementation; demonstrate unit, API/PostgreSQL, UI/style, authorization, migration/regression, responsive/accessibility and E2E coverage.
- **FR-25:** Complete Issues, reviewed feature PRs into lab3-staging, release into main, truthful AI/reviewer records and final submission evidence.

Rendered specification - Business Rules and Authorization

5. Business Rules and Authorization

Authentication and account rules

- ****BR-01:**** Only active Users with a non-null password hash and valid credentials authenticate. Unknown email, wrong password, inactive and unprovisioned accounts use identical 401 INVALID_CREDENTIALS feedback.
- ****BR-02:**** mustChangePassword=true blocks normal protected endpoints with 403 PASSWORD_CHANGE_REQUIRED, including reference data. A restricted initial-password session sets expiresAt = createdAt + 15 minutes, is valid only while backend time is strictly earlier than expiresAt, and expires when now >= expiresAt. It has no idle timeout: requests never extend expiresAt and never update lastSeenAt. After expiry, me/change-password return 401 SESSION_REQUIRED; idempotent logout remains 204.
- ****BR-03:**** Requester ownership comes only from the authenticated User. Ignore X-Requester-Id as identity; reject unsupported requesterId JSON/query fields with 400; neither mechanism can impersonate another account.
- ****BR-04:**** Public Comments are readable by the owning Requester and operational roles. Internal Notes are readable only by IT Staff/Administrator, never returned to a Requester through any projection.
- ****BR-05:**** Requester resolution indication does not set Resolved or Closed. Only operational roles perform formal transitions.
- ****BR-06:**** One User has exactly one role: REQUESTER, IT_STAFF or ADMINISTRATOR. No role array or self-registration.
- ****BR-07:**** Normalize email with trim/lowercase; validate syntax and maximum 254 characters; enforce uniqueness in PostgreSQL, including inactive accounts. Trim names to 1-120 characters.
- ****BR-08:**** Passwords contain 15-128 Unicode code points, allow spaces/Unicode, reject whitespace-only and over 512 UTF-8 bytes, and are never trimmed or silently truncated. New/initial passwords use the same policy; confirmation must match exactly; a replacement must differ from the current password. No mandatory composition rule is inferred from sample images.
- ****BR-09:**** The proposed Node.js password-hashing profile is asynchronous scrypt with N=131072, r=8, p=1, 64-byte output, random 16-byte salt and maxmem=256 MiB. Before implementation freezes this profile, run PERF-01 on the intended local and CI runtimes. Record latency and peak memory for serial and two concurrent hashes; the gate is p95 <= 2 seconds and additional peak RSS <= 320 MiB for two concurrent hashes. If it fails, revise and review the profile and its tests before coding; never silently lower the cost in code. Store a versioned encoding of parameters/salt/hash; use constant-time comparison and a dummy hash for unavailable users. SHA-256 is only for random session-token hashes and existing Ticket payload idempotency, not passwords.
- ****BR-10:**** PostgreSQL holds opaque sessions; issue a random 32-byte token through an HttpOnly cookie. Do not put session credentials/passwords in browser storage, URLs, client bundles, repository files, screenshots, traces or logs.
- ****BR-11:**** Normal sessions expire after 8 hours absolute or 30 minutes idle, whichever occurs first; their lastSeenAt may advance after a valid request without changing absolute expiresAt. Restricted sessions use only BR-02's fixed 15-minute expiry. Login rotates tokens; logout deletes the current session if present and always clears the cookie. Repeated logout, including absent/expired sessions, succeeds with empty 204 so it is idempotent. A valid active session still requires its CSRF token; an absent/expired session has no token to validate. Password change/reset deletes all target sessions. No remember-me feature.
- ****BR-12:**** Session middleware reloads current User activation/role/password-change state on every protected request; database failures fail closed. It may update lastSeenAt only for normal sessions and never for restricted sessions. For password change, derive the candidate hash and random replacement token/CSRF values before the database transaction. The transaction locks/rechecks the active User and authenticated session snapshot, updates the credential/password flags/version, deletes every old session and inserts exactly one normal replacement session. Any database-step failure rolls back all three state changes, so the old credential/sessions remain authoritative. Only after commit may the server emit Set-Cookie and AuthResponse. If response delivery fails after commit, the new password is authoritative, all old sessions remain revoked and the user recovers through normal login with the new password. Account edits/reset revoke target sessions within their own account transaction and do not create a replacement session unless the endpoint explicitly says so.
- ****BR-13:**** Require a configured exact browser Origin, credentialed non-wildcard CORS, JSON-only login and a per-session X-CSRF-Token for authenticated POST/PATCH/DELETE, including multipart upload. Missing/untrusted Origin or invalid CSRF is 403 CSRF_INVALID; SameSite alone is insufficient.
- ****BR-14:**** Allow at most five failed logins per normalized-email/IP pair per fixed 15-minute window and 30 per IP/window. The next attempt returns generic 429 LOGIN_RATE_LIMITED with Retry-After seconds. Successful login resets the pair bucket; no persistent account lock/unlock UI. For this local-lab sprint, use a bounded in-memory throttle keyed by hashes of normalized email/IP; restart resets the buckets. Production-wide distributed throttling is outside Lab 3.
- ****BR-15:**** Admin create/reset accepts an entered initial password and never returns it. Deliver it manually through the local-lab arrangement; no email. Initial-password provisioning is specified in section 7, not deferred to implementation.
- ****BR-16:**** No Administrator can deactivate their own account. No edit can demote/deactivate the last active Administrator. Serialize account-safety writes using a shared PostgreSQL transaction advisory lock and recheck counts in that transaction, including concurrent attempts.

- **BR-17:** Deactivate instead of deleting users. Name/email/role/activation edits revoke all target sessions; editing one's own account therefore requires signing in again. All admin updates use expectedVersion; stale edits return 409.

Authorization matrix (explicit project decision)

Administrator primarily manages accounts, but this contract explicitly also permits operational Ticket access/actions for Administrators. This resolves the handout's Administrator-eligible Ticket Owner/IT Priority rules and required Comment/Note visibility while keeping a single assigned role. Administrator is not automatically a Requester. This extension is permitted by section 4.3 and must be reviewed with the contract.

Operation	Anonymous	Initial-password session	Requester	IT Staff	Administrator	
---	---	---	---	---	---	
Health; login	Yes	Yes	Yes	Yes	Yes	
Current user; password change	No	Yes	Yes	Yes	Yes	
Logout/clear cookie	Yes, empty 204	Yes	Yes	Yes	Yes	
Active categories/related systems	No	No	Yes	Yes	Yes	
Create Ticket; My Tickets	No	No	Yes, self	No	No	
Requester Ticket detail	No	No	Own only	No	No	
Shared queue; operational detail; eligible owners	No	No	No	Yes	Yes	
Claim/assign; IT Priority; status transitions	No	No	No	Yes	Yes	
Read attachment metadata/download	No	No	Own only	Any Ticket	Any Ticket	
Upload/soft-remove attachments	No	No	Own only	No	No	
Read/create Public Comments	No	No	Own only	Any Ticket	Any Ticket	
Read/create Internal Notes	No	No	No	Any Ticket	Any Ticket	
Problem Appears Resolved	No	No	Own eligible Ticket	No	No	
List/create/edit users; initial-password reset	No	No	No	No	Yes	

- **BR-18:** Every protected resource route checks session, account state and permitted role before parsing/querying resources; authenticated Requester resource queries then scope by requesterId. Login/health are public and logout has the BR-11 idempotent absent-session exception. Operational writes are shared-role actions, not restricted to the currently assigned staff member.

- **BR-19:** Anonymous access is 401; wrong-role endpoints are 403; missing and non-owned Requester Ticket/Attachment/Comment parents use the same 404 RESOURCE_NOT_FOUND, with no data/bytes or resource-existence hints. Note endpoints return 403 for Requesters before lookup.

Rendered specification - Acceptance Criteria

Lab 3 Sprint Engineering Specification

Contract version: 1.0, prepared 2026-09-15. Status: prepared for student/peer review; implementation and product completion are not claimed.

Source: supplied Lab_3_sheet.pdf, all 18 pages, especially sections 4-10 and 14. Lab 2 baseline: local main commit 439ee7e. See README.md (README.md) for the inspected baseline and implementation-plan.md (implementation-plan.md) for the proposed Issues.

The handout is the assignment source. Requirements explicitly fixed by it remain mandatory. Concrete choices below resolve its intentionally unspecified details; they are project decisions, not quotations from the instructor. Sample images do not override written exclusions (including email reset, Service Actions and advanced user management).

1. Sprint Goal

Extend the existing Requester MVP with email/password authentication, mandatory initial-password change, backend role/ownership enforcement, an operational IT Staff Ticket Queue and Ticket Detail, shared Public Comments, restricted Internal Notes, and minimalist Administrator User Management. Preserve existing Tickets, Attachments, numbering, reference data, and permitted Requester behavior while replacing the Development Requester selector.

2. Stakeholder Request

Real accounts must replace the temporary requester context. Requesters continue handling their own submissions and communicate with support. IT Staff find, own, prioritize and progress work. Administrators manage accounts. Every screen and API observes the authorization matrix; hidden controls alone never grant protection. All screens extend the existing Zen Green application.

3. Scope

Included: the sprint goal; forward-only Prisma/PostgreSQL migrations and idempotent local seed; all four normative contract documents; traceable tests; Issues, feature PRs, peer review, staged integration, visual evidence and the final nine-part PDF.

Excluded: self-registration; invitations or password-reset email; MFA, social login and SSO; Actions Taken/Service Actions; SLA/escalation/notifications; analytics beyond simple queue totals; organizations/departments/multi-tenancy; multiple roles per user; user deletion, bulk operations, import/export, role/account-history screens, profile pictures, account unlocking or advanced identity management; mandatory admin pagination or multi-column sorting; production deployment/cloud changes. Requester editing/deleting saved Ticket fields is not added: Lab 2 implemented read-only detail and Attachment management.

4. Functional Requirements

- **FR-01:** Authenticate an active, provisioned User using email/password with safe failure feedback and bounded attempts.
- **FR-02:** A successful initial-password login permits only current-user retrieval, mandatory password change and logout before normal application access; its restricted session expires exactly 15 minutes after issuance regardless of activity.
- **FR-03:** Change password after current-password verification and valid new-password confirmation; atomically record passwordChangedAt, increment User.version/updatedAt, revoke old sessions and persist a fresh normal session before its cookie is sent.
- **FR-04:** Restore the session through current-user retrieval; display name/role; logout invalidates server access and clears account-specific UI state.
- **FR-05:** Enforce the matrix in section 5 on the backend and reflect it in navigation, controls and direct screen guards.
- **FR-06:** Replace RequesterUser with User while preserving IDs, activation, Ticket ownership and Attachment removal attribution; remove the selector, Change Requester and requester storage key.
- **FR-07:** Continue Lab 2 create/list/detail, reference data, numbering, idempotency and validation using the authenticated Requester's ID.
- **FR-08:** Preserve owner-only upload/download/soft removal, removed metadata, private file storage and Lab 2 file limits.
- **FR-09:** Requesters read/write Public Comments only on their own Tickets and indicate that a problem appears resolved without changing status.
- **FR-10:** IT Staff retrieve a shared queue with search, filters, deterministic sorting and pagination defined in api-spec.md.
- **FR-11:** IT Staff open Ticket Detail with submitted information, requester, ownership, both priorities, status, Attachments and role-permitted conversations.
- **FR-12:** Claim, assign or reassign one primary Ticket Owner using validated active eligible accounts and concurrency checks; retain owner-change provenance when ownership changes or an account loses eligibility. Staff manual unassign is excluded from Lab 3.
- **FR-13:** Initialize IT Priority from Requested Priority and permit operational updates without changing the submitted Requested Priority.
- **FR-14:** Enforce all eight statuses and the transition matrix, resolution requirements, confirmation and stale-write behavior.
- **FR-15:** Retrieve/create Public Comments with backend author/time, plain-text rendering and append-only semantics.
- **FR-16:** Retrieve/create Internal Notes for operational roles only; prevent note content/metadata/counts from Requester responses.
- **FR-17:** Administrators list users, search name/email, optionally filter one role, and create accounts with one role and initial password.
- **FR-18:** Administrators edit name/email/role/activation, prevent duplicates and protect self/last-active-Administrator safety.
- **FR-19:** Administrators set a new initial password; invalidate the target's sessions and require password change at next login.
- **FR-20:** Deactivation or role/account changes invalidate affected sessions; losing owner eligibility safely unassigns affected Tickets.
- **FR-21:** Extend the existing Zen Green tokens, reusable controls, badges and shell across desktop/tablet/mobile with keyboard and accessible feedback.
- **FR-22:** Provide relevant loading, saving, validation, success, empty/no-results, forbidden, not-found, conflict and safe failure feedback.
- **FR-23:** Provision migrated accounts safely, seed required roles/workflow examples repeatedly without resetting existing credentials or work.
- **FR-24:** Create the test plan before implementation; demonstrate unit, API/PostgreSQL, UI/style, authorization, migration/regression, responsive/accessibility and E2E coverage.
- **FR-25:** Complete Issues, reviewed feature PRs into lab3-staging, release into main, truthful AI/reviewer records and final submission evidence.

5. Business Rules and Authorization

Authentication and account rules

- ****BR-01:**** Only active Users with a non-null password hash and valid credentials authenticate. Unknown email, wrong password, inactive and unprovisioned accounts use identical 401 INVALID_CREDENTIALS feedback.
- ****BR-02:**** mustChangePassword=true blocks normal protected endpoints with 403 PASSWORD_CHANGE_REQUIRED, including reference data. A restricted initial-password session sets expiresAt = createdAt + 15 minutes, is valid only while backend time is strictly earlier than expiresAt, and expires when now >= expiresAt. It has no idle timeout: requests never extend expiresAt and never update lastSeenAt. After expiry, me/change-password return 401 SESSION_REQUIRED; idempotent logout remains 204.
- ****BR-03:**** Requester ownership comes only from the authenticated User. Ignore X-Requester-Id as identity; reject unsupported requesterId JSON/query fields with 400; neither mechanism can impersonate another account.
- ****BR-04:**** Public Comments are readable by the owning Requester and operational roles. Internal Notes are readable only by IT Staff/Administrator, never returned to a Requester through any projection.
- ****BR-05:**** Requester resolution indication does not set Resolved or Closed. Only operational roles perform formal transitions.
- ****BR-06:**** One User has exactly one role: REQUESTER, IT_STAFF or ADMINISTRATOR. No role array or self-registration.
- ****BR-07:**** Normalize email with trim/lowercase; validate syntax and maximum 254 characters; enforce uniqueness in PostgreSQL, including inactive accounts. Trim names to 1-120 characters.
- ****BR-08:**** Passwords contain 15-128 Unicode code points, allow spaces/Unicode, reject whitespace-only and over 512 UTF-8 bytes, and are never trimmed or silently truncated. New/initial passwords use the same policy; confirmation must match exactly; a replacement must differ from the current password. No mandatory composition rule is inferred from sample images.
- ****BR-09:**** The proposed Node.js password-hashing profile is asynchronous script with N=131072, r=8, p=1, 64-byte output, random 16-byte salt and maxmem=256 MiB. Before implementation freezes this profile, run PERF-01 on the intended local and CI runtimes. Record latency and peak memory for serial and two concurrent hashes; the gate is p95 <= 2 seconds and additional peak RSS <= 320 MiB for two concurrent hashes. If it fails, revise and review the profile and its tests before coding; never silently lower the cost in code. Store a versioned encoding of parameters/salt/hash; use constant-time comparison and a dummy hash for unavailable users. SHA-256 is only for random session-token hashes and existing Ticket payload idempotency, not passwords.
- ****BR-10:**** PostgreSQL holds opaque sessions; issue a random 32-byte token through an HttpOnly cookie. Do not put session credentials/passwords in browser storage, URLs, client bundles, repository files, screenshots, traces or logs.
- ****BR-11:**** Normal sessions expire after 8 hours absolute or 30 minutes idle, whichever occurs first; their lastSeenAt may advance after a valid request without changing absolute expiresAt. Restricted sessions use only BR-02's fixed 15-minute expiry. Login rotates tokens; logout deletes the current session if present and always clears the cookie. Repeated logout, including absent/expired sessions, succeeds with empty 204 so it is idempotent. A valid active session still requires its CSRF token; an absent/expired session has no token to validate. Password change/reset deletes all target sessions. No remember-me feature.
- ****BR-12:**** Session middleware reloads current User activation/role/password-change state on every protected request; database failures fail closed. It may update lastSeenAt only for normal sessions and never for restricted sessions. For password change, derive the candidate hash and random replacement token/CSRF values before the database transaction. The transaction locks/rechecks the active User and authenticated session snapshot, updates the credential/password flags/version, deletes every old session and inserts exactly one normal replacement session. Any database-step failure rolls back all three state changes, so the old credential/sessions remain authoritative. Only after commit may the server emit Set-Cookie and AuthResponse. If response delivery fails after commit, the new password is authoritative, all old sessions remain revoked and the user recovers through normal login with the new password. Account edits/reset revoke target sessions within their own account transaction and do not create a replacement session unless the endpoint explicitly says so.
- ****BR-13:**** Require a configured exact browser Origin, credentialed non-wildcard CORS, JSON-only login and a per-session X-CSRF-Token for authenticated POST/PATCH/DELETE, including multipart upload. Missing/untrusted Origin or invalid CSRF is 403 CSRF_INVALID; SameSite alone is insufficient.
- ****BR-14:**** Allow at most five failed logins per normalized-email/IP pair per fixed 15-minute window and 30 per IP/window. The next attempt returns generic 429 LOGIN_RATE_LIMITED with Retry-After seconds. Successful login resets the pair bucket; no persistent account lock/unlock UI. For this local-lab sprint, use a bounded in-memory throttle keyed by hashes of normalized email/IP; restart resets the buckets. Production-wide distributed throttling is outside Lab 3.
- ****BR-15:**** Admin create/reset accepts an entered initial password and never returns it. Deliver it manually through the local-lab arrangement; no email. Initial-password provisioning is specified in section 7, not deferred to implementation.
- ****BR-16:**** No Administrator can deactivate their own account. No edit can demote/deactivate the last active Administrator. Serialize account-safety writes using a shared PostgreSQL transaction advisory lock and recheck counts in that transaction, including concurrent attempts.

- **BR-17:** Deactivate instead of deleting users. Name/email/role/activation edits revoke all target sessions; editing one's own account therefore requires signing in again. All admin updates use expectedVersion; stale edits return 409.

Authorization matrix (explicit project decision)

Administrator primarily manages accounts, but this contract explicitly also permits operational Ticket access/actions for Administrators. This resolves the handout's Administrator-eligible Ticket Owner/IT Priority rules and required Comment/Note visibility while keeping a single assigned role. Administrator is not automatically a Requester. This extension is permitted by section 4.3 and must be reviewed with the contract.

Operation Anonymous Initial-password session Requester IT Staff Administrator
--- --- --- --- --- ---
Health; login Yes Yes Yes Yes Yes
Current user; password change No Yes Yes Yes Yes
Logout/clear cookie Yes, empty 204 Yes Yes Yes Yes
Active categories/related systems No No Yes Yes Yes
Create Ticket; My Tickets No No Yes, self No No
Requester Ticket detail No No Own only No No
Shared queue; operational detail; eligible owners No No No Yes Yes
Claim/assign; IT Priority; status transitions No No No Yes Yes
Read attachment metadata/download No No Own only Any Ticket Any Ticket
Upload/soft-remove attachments No No Own only No No

Rendered specification - Migration decisions and Product Definition of Done

The full linked specification remains the source of truth; this PDF renders the grading-relevant contract excerpts.

11. Assumptions, Decisions and References

Scope review after PR #68 feedback: authentication, role/ownership enforcement, first-password change, data preservation, Staff queue/operations, public/private separation and minimal Admin management are handout-required. Opaque database sessions, per-session CSRF, local throttle limits, absolute/idle expiry, concurrency versions, public resolution summary/reasons and one-time provisioning CLI are project choices that make those required workflows testable and safe; because they remain in BR/AC, they are Product DoD commitments. To keep the sprint focused, persisted/distributed throttle storage and backend conversation request-key idempotency were removed from Lab 3; no LoginThrottle table, conversation replay API or account-history screen is required. TicketOwnerChange is the minimal internal provenance needed when a terminal owner's account becomes ineligible; it has no UI/API list screen. Scrypt cost is a proposal subject to PERF-01 before auth coding. Any other project choice may be changed only by a reviewed contract update before dependent implementation, not silently weakened to match code.

Security guidance consulted 2026-09-15: OWASP Password Storage

(https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html) for memory-hard hashing; Node.js crypto

(<https://nodejs.org/docs/latest-v22.x/api/crypto.html>) for scrypt/randomness/comparison; OWASP Session Management

(https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html) and OWASP CSRF Prevention

(https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html) for session/cookie/write protection. Exact policy values and architecture are our implementation decisions, not claims that the handout specified them.

Specification timing evidence: PR #68 was the contract review before the main implementation PR sequence (#69 onward).

[PR #68 - Engineering Contract review](#)

Answer Part 3: Test DD and Traceability

[Full tests.md](#)

Rendered tests.md - strategy / planned coverage

Lab 3 Test Plan and Traceability

Version 1.0, planned 2026-09-15 before Lab 3 implementation. Rows remain ****Planned / Not run**** until an implementation PR records reproducible evidence; rows marked below have reproducible evidence from PR #70, PR #71, PR #72 or the Issue #56 implementation PR. A marked row records the executed coverage while any unlisted parameterized cases remain part of the planned matrix.

1. Baseline, execution and isolation

Current local main 439ee7e implements Lab 2. Its historical README/tests record 62 server, 54 client and 9 E2E passes; these were not rerun for this documentation task and do not prove Lab 3 completion. Existing unit/API tests use Vitest/Supertest, UI tests React Testing Library, and E2E Playwright in client/e2e/lab-02. The Lab 3 foundation now requires an explicit isolated TEST_DATABASE_URL for PostgreSQL and Playwright integration runs; missing configuration fails closed instead of falling back to a development database.

All database-writing tests use required TEST_DATABASE_URL validated as PostgreSQL, a database name containing test, and a different host/port/database from DATABASE_URL. A different schema inside the development database is rejected; database isolation is required. No credential/query-order trick can bypass equality checks; guard errors omit connection URLs. Set the test URL before Prisma initialization; no development fallback. Migrate/seed only the validated target; test fixture creation/cleanup uses run-specific markers and a dedicated temporary Attachment directory. Pure unit/mock tests run without database configuration. Full verification must fail if a required database suite would skip; it cannot report a skipped suite as passing.

Migration tests create a Lab 2 schema on the isolated target using committed historical migrations, populate representative Tickets/Attachments/removal records and run new forward migrations; compare row/ID/FK/sequence/file hashes. Never migrate reset, truncate or clean up the user's development database. Seed twice and repeat provisioning to verify no credential/work/state resets.

Server contract paths: server/tests/lab-03/*.test.ts. UI paths follow this repo's client/tests/lab-03 convention (the handout's client/... location is illustrative). E2E paths are client/e2e/lab-03/*.spec.ts, matching current Playwright testDir. Include api-spec exact statuses/projections in assertions, not just button snapshots.

2. Planned test cases

Test ID	Type	ACs	Behavior and expected result	Planned test file	Final status
---	---	---	---	---	---
UNIT-01	Unit	AC-03	Password bounds15/128, Unicode/spaces, whitespace-only,512-byte bound, exact confirmation and no truncation/trim		
UNIT-02	Unit	AC-03	script encoding/parameters/salts, valid/invalid verification and constant-time-compatible comparisons; no plainte		
PERF-01	Performance gate	AC-03	Before auth coding, benchmark proposed script profile on intended local and CI runtimes: 10 serial has		
UNIT-03	Unit	AC-17	Parameterized full8x8 transition matrix: every allowed edge and every denied edge, including same-state	server/	
UNIT-04	Unit	AC-12	Query normalization/defaults, priority rank, tie-breakers, duplicate/unknown/out-of-range/safe-offset parameters		
UNIT-05	Unit	AC-31	Test-target guard rejects missing/malformed/non-test/same targets despite credential/query-order changes; safe mes		
UNIT-06	Unit	AC-19, AC-20, AC-21	Content trim/1-5000 bounds and projection separation; script-like text is data	server/tests/lab-03	
API-01	API	AC-01	Active valid login yields safe AuthResponse/cookie; malformed input400 and unavailable/wrong/inactive/unprovisioned		
API-02	API	AC-02	Restricted session allows only me/change/logout; issued t0 is valid at t0+15m-epsilon, activity at t0+14m59s changes		
API-03	API/PostgreSQL	AC-03	Wrong current password401 and invalid new/confirmation/same400; fault injection at User update/session de		
API-04	API	AC-04	me returns actual role/flag; missing/expired/idle/revoked/inactive sessions401; store failure safe500/no access	se	
API-05	API	AC-05	Valid logout204 clears/deletes token; old token protected replay401; repeated/absent/expired logout204; valid-sessi		
API-06	API	AC-06	Parameterize every protected endpoint/method against every role, including restricted/anonymous; matrix denial prec		
API-07	API	AC-06	A cookie plus B requester header cannot impersonate B; requesterId body/query400; non-owner resource safe404/no byte		
API-08	API	AC-20	Requester Note GET/POST403 even for missing parents; no note content/author/count through detail/comments/errors	se	
API-09	API	AC-27	Trusted/untrusted/missing Origin, exact credentialed CORS; JSON login only; CSRF on active-session JSON/multipart/l		
API-10	API	AC-27	Fifth failed pair/thirtieth IP failure allowed; next429/Retry-After; clock expiry/reset and process-restart bucket		
API-11	API	AC-27	Cookie path/HttpOnly/SameSite/local Secure exception, HTTPS Secure, token rotation, absolute8h/idle30m expiry	serv	
API-12	API	AC-09	Cookie-owned create uses existing validation/number/date/NEW/request key; IT Priority copies request; client workflo		
API-13	API/PostgreSQL	AC-09	Sequential/concurrent create replay creates one Ticket; changed payload409; replay preserves later owner		
API-14	API	AC-09	Owned list/detail and AND filters/sort/pages retained; all8 statuses accepted; other Requester's data404/absent	se	
API-15	API/PostgreSQL	AC-10	Valid upload/file bytes/removal attribution; active limit/type/signature/size/invalid reason; removed/non		
API-16	API	AC-10, AC-14	Staff reads/downloads any active Attachment; upload/remove403; wrong parent/removed404, storage paths absent		
API-17	API	AC-11	Development Requester endpoint404; headers supply no identity; runtime client helper/key removed	server/tests/lab-	

API-18	API/PostgreSQL	AC-12	Shared queue search/each combined filter, mine/unassigned/specific owner, sort priority/ties and accurate
API-19	API	AC-12	Unknown/repeated/invalid query400, empty/beyond-end page200 accurate metadata, no Requester access server/tests/lab
API-20	API	AC-14	Detail exact DTO/read-only submitted values/owner/indication/resolution/file continuity; missing404; wrong role403
API-21	API/PostgreSQL	AC-15	Claim self, already-self no-op, other owner409, eligible assign/reassign with ASSIGNED/REASSIGNED proven
API-22	API/PostgreSQL	AC-15, AC-16, AC-17, AC-18	Competing owner/priority/status/indication writes: one version wins; losers409/no p
API-23	API	AC-16	IT Priority changes independently; invalid enum400; unchanged no-op; Requester403; terminal/stale409 server/tests.
API-24	API/PostgreSQL	AC-17	Allowed transitions/input bounds; resolution/close timestamps; reopen resets public resolution/indication
API-25	API	AC-17	Every forbidden/same-state transition409, irrelevant fields400; requester transition403; no Actions Taken dependency
API-26	API/PostgreSQL	AC-18	Owner indication eligible states, backend author/time, current-version no-op; status unchanged; non-owner
API-27	API/PostgreSQL	AC-19	Public content bounds, exact author/time, chronological order and empty list; one valid POST creates one
API-28	API/PostgreSQL	AC-20	Staff/Admin private append/read on terminal Tickets; edit/delete405; no cross-parent leak or Requester no
API-29	API	AC-22	Admin list fields/name-email OR search/role AND filter/default order/empty; non-admin403; unknown params400 server
API-30	API/PostgreSQL	AC-23	Admin create/edit one role/name/email/Boolean; duplicate normalized/inactive email409 and concurrent dup
API-31	API/PostgreSQL	AC-15, AC-24	Deactivate/demote/account edit revokes sessions and unassigns active and CLOSED/CANCELLED owners :
API-32	API/PostgreSQL	AC-25	Self-deactivation409; last active admin demotion/deactivation409; simultaneous changes cannot eliminate a
API-33	API/PostgreSQL	AC-26	Reset validates/salts/hash/flag/revocation/version; no response password; self reset returns reauthentic
API-34	API	AC-28	Invalid JSON/bounded payloads and injected DB/file/service failures use exact safe errors/correlationId; no sensitiv
DB-01	Migration	AC-07	Isolated historical schema -> forward migration: IDs/counts/activation/FKs/numbering/removal fields and sample
DB-02	Seed/provisioning	AC-08	NULL-hash users provision once; repeats skip changed credentials/inactive states; seed twice minima24
DB-03	Regression	AC-07, AC-09, AC-24	Migration sequence continues; historical create replay/attachment links survive and author/requ
DB-04	Concurrency	AC-15, AC-24, AC-25	Owner assignment racing with account demotion cannot persist an ineligible owner; terminal own

Rendered tests.md - AC traceability excerpt

Traceability rows preserve AC IDs, test type/path and status in the source document.

API-01	API	AC-01	Active valid login yields safe AuthResponse/cookie; malformed input400 and unavailable/wrong/inactive/unprovisioned
API-02	API	AC-02	Restricted session allows only me/change/logout; issued t0 is valid at t0+15m-epsilon, activity at t0+14m59s changes
API-03	API/PostgreSQL	AC-03	Wrong current password401 and invalid new/confirmation/same400; fault injection at User update/session de
API-04	API	AC-04	me returns actual role/flag; missing/expired/idle/revoked/inactive sessions401; store failure safe500/no access se
API-05	API	AC-05	Valid logout204 clears/deletes token; old token protected replay401; repeated/absent/expired logout204; valid-sessio
API-06	API	AC-06	Parameterize every protected endpoint/method against every role, including restricted/anonymous; matrix denial prec
API-07	API	AC-06	A cookie plus B requester header cannot impersonate B; requesterId body/query400; non-owner resource safe404/no byte
API-08	API	AC-20	Requester Note GET/POST403 even for missing parents; no note content/author/count through detail/comments/errors s
API-09	API	AC-27	Trusted/untrusted/missing Origin, exact credentialed CORS; JSON login only; CSRF on active-session JSON/multipart/l
API-10	API	AC-27	Fifth failed pair/thirtieth IP failure allowed; next429/Retry-After; clock expiry/reset and process-restart bucket
API-11	API	AC-27	Cookie path/HttpOnly/SameSite/local Secure exception, HTTPS Secure, token rotation, absolute8h/idle30m expiry serv
API-12	API	AC-09	Cookie-owned create uses existing validation/number/date/NEW/request key; IT Priority copies request; client workfl
API-13	API/PostgreSQL	AC-09	Sequential/concurrent create replay creates one Ticket; changed payload409; replay preserves later owner.
API-14	API	AC-09	Owned list/detail and AND filters/sort/pages retained; all8 statuses accepted; other Requester's data404/absent se
API-15	API/PostgreSQL	AC-10	Valid upload/file bytes/removal attribution; active limit/type/signature/size/invalid reason; removed/non
API-16	API	AC-10, AC-14	Staff reads/downloads any active Attachment; upload/remove403; wrong parent/removed404, storage paths absent
API-17	API	AC-11	Development Requester endpoint404; headers supply no identity; runtime client helper/key removed server/tests/lab
API-18	API/PostgreSQL	AC-12	Shared queue search/each combined filter, mine/unassigned/specific owner, sort priority/ties and accurate
API-19	API	AC-12	Unknown/repeated/invalid query400, empty/beyond-end page200 accurate metadata, no Requester access server/tests/lab
API-20	API	AC-14	Detail exact DTO/read-only submitted values/owner/indication/resolution/file continuity; missing404; wrong role403
API-21	API/PostgreSQL	AC-15	Claim self, already-self no-op, other owner409, eligible assign/reassign with ASSIGNED/REASSIGNED proven
API-22	API/PostgreSQL	AC-15, AC-16, AC-17, AC-18	Competing owner/priority/status/indication writes: one version wins; losers409/no p
API-23	API	AC-16	IT Priority changes independently; invalid enum400; unchanged no-op; Requester403; terminal/stale409 server/tests.
API-24	API/PostgreSQL	AC-17	Allowed transitions/input bounds; resolution/close timestamps; reopen resets public resolution/indication
API-25	API	AC-17	Every forbidden/same-state transition409, irrelevant fields400; requester transition403; no Actions Taken dependency
API-26	API/PostgreSQL	AC-18	Owner indication eligible states, backend author/time, current-version no-op; status unchanged; non-owner
API-27	API/PostgreSQL	AC-19	Public content bounds, exact author/time, chronological order and empty list; one valid POST creates one
API-28	API/PostgreSQL	AC-20	Staff/Admin private append/read on terminal Tickets; edit/delete405; no cross-parent leak or Requester no
API-29	API	AC-22	Admin list fields/name-email OR search/role AND filter/default order/empty; non-admin403; unknown params400 server
API-30	API/PostgreSQL	AC-23	Admin create/edit one role/name/email/Boolean; duplicate normalized/inactive email409 and concurrent dup
API-31	API/PostgreSQL	AC-15, AC-24	Deactivate/demote/account edit revokes sessions and unassigns active and CLOSED/CANCELLED owners :
API-32	API/PostgreSQL	AC-25	Self-deactivation409; last active admin demotion/deactivation409; simultaneous changes cannot eliminate a
API-33	API/PostgreSQL	AC-26	Reset validates/salts/hash/flag/revocation/version; no response password; self reset returns reauthentic

API-34	API	AC-28	Invalid JSON/bounded payloads and injected DB/file/service failures use exact safe errors/correlationId; no sensitiv
DB-01	Migration	AC-07	Isolated historical schema -> forward migration: IDs/counts/activation/FKs/numbering/removal fields and sample
DB-02	Seed/provisioning	AC-08	NULL-hash users provision once; repeats skip changed credentials/inactive states; seed twice minima24
DB-03	Regression	AC-07, AC-09, AC-24	Migration sequence continues; historical create replay/attachment links survive and author/requ
DB-04	Concurrency	AC-15, AC-24, AC-25	Owner assignment racing with account demotion cannot persist an ineligible owner; terminal own
UI-01	UI	AC-01, AC-28	Login labels/policy validation/busy/generic failure/inactive/rate-limit/network retry; password cleared safely
UI-02	UI	AC-02, AC-03	Mandatory/voluntary password modes, fixed initial-session deadline/no activity extension, no skip, validation.
UI-03	UI	AC-04, AC-05, AC-06, AC-11	Role navigation/guards/bootstrap-no-flash; legacy key clear; logout and stale cross-account requ
UI-04	UI/regression	AC-09, AC-10, AC-11	Adapt Lab 2 Create/My Tickets/Detail/Attachment tests to session; validation/idempotency/file
UI-05	UI	AC-12, AC-13	Queue controls reset page, badges/owner/open, empty/no-results/loading/forbidden/error and beyond-end recovery
UI-06	UI	AC-14, AC-15, AC-16, AC-17	Detail read-only values vs operational controls; claim/assign/reassign but no manual-unassign act
UI-07	UI	AC-18, AC-19, AC-20, AC-21	Requester indication/comment flow; public/private independent drafts/buttons; inert scripts; amb
UI-08	UI	AC-22, AC-23, AC-25	Admin list/create/edit/search/role/activation, duplicate/one-role/last-admin/self/stale errors and retr
UI-09	UI	AC-24, AC-26, AC-28	Reset/account edit confirmations, cleared passwords, self reauthentication and safe processing/failure
STYLE-01	UI style	AC-21, AC-29	Shared Zen Green tokens/components, text-bearing badges, readonly/editable and Public/Private distinct
A11Y-01	UI accessibility	AC-30	Labels/errors/live state and first-invalid focus; keyboard dialog trap/Escape/return focus, menus and
E2E-01	E2E	AC-01, AC-02, AC-03, AC-04, AC-05, AC-27	Real valid/invalid/inactive login; mandatory-session fixed 15-minute boundary; at
E2E-02	E2E/regression	AC-06, AC-09, AC-10, AC-11, AC-18, AC-19	Requester A/B create/list/detail/files/comments/indication; identity s
E2E-03	E2E	AC-12, AC-13, AC-14, AC-15, AC-16, AC-17, AC-20, AC-21	Real queue -> claim/reassign/priority/status/public/private/file d
E2E-04	E2E	AC-22, AC-23, AC-24, AC-25, AC-26	Admin search/create/edit/activate/reset/first-change and real revocation; self/last-adm
RESP-01	Browser responsive	AC-29, AC-30	Every major screen at1440/768/390/360 widths and200% zoom; actions/focus reachable, no page c
VIS-01	Manual visual	AC-13, AC-21, AC-28, AC-29, AC-30	Screenshot checklist, actual contrast/keyboard/zoom, failure/conflict states a
RELEASE-01	Release audit	AC-31, AC-32	Cross-reference actual final-main result/output for every listed UNIT/PERF/API/DB/UI/STYLE/A11Y

Table contains 63 unique planned Test IDs. A row represents a case group; parameterized cases may produce a different automated assertion/test count. Final reports must use observed counts, not this row count.

Rendered tests.md - final release synchronization

Final release synchronization - 2026-10-03

Final release PR #87 promoted reviewed lab3-staging head c03494c to main as merge commit d152bc10d4fe146e59304d9d09343f81295429ad. Peepipat-Suesoongnuen approved PR #87 in review 5401333806 after reviewing the 58-file release diff and exact-head CI/provenance.

The exact final-main push on d152bc1 is green: Client CI run 37131535259 (#142) SUCCESS; Server CI run 37131535224 (#155) SUCCESS; E2E CI run 37131535237 (#124) SUCCESS. This supersedes 55d80fe as the final-main revision while preserving the earlier detailed suite counts and the PR #86 25/25 responsive evidence.

PR #86 was approved by Peepipat-Suesoongnuen in review 5401247258; that reviewer inspected all 64 files and opened the screenshot evidence, confirming the screenshots were real and contained no secret leakage. The review explicitly recorded the formal human sign-off as still pending. Therefore RELEASE-01 automated/release evidence is PASS on d152bc1, while the final human VIS-01/A11Y-01 checklist remains the only non-automatable completion gate. An AI/coding-agent inspection must not be relabeled as human sign-off.

Exact released-main CI after PR #89 merge (main 319c34c): Client run 37136334077 SUCCESS; Server run 37136334040 SUCCESS; E2E run 37136334094 SUCCESS.

[Client CI run 37136334077](#)

[Server CI run 37136334040](#)

[E2E CI run 37136334094](#)

Rendered passing output: final-main-client-ci.log

```
test■UNKNOWN STEP■2026-10-02T19:34:00.0184863Z ^[[36mvite v6.4.3 ^[[32mbuilding for production...^[[36m^[[39m
test■UNKNOWN STEP■2026-10-02T19:34:00.0861478Z transforming...
test■UNKNOWN STEP■2026-10-02T19:34:01.0144781Z ^[[32m✓^[[39m 32 modules transformed.
test■UNKNOWN STEP■2026-10-02T19:34:01.1626178Z rendering chunks...
test■UNKNOWN STEP■2026-10-02T19:34:01.1702144Z computing gzip size...
test■UNKNOWN STEP■2026-10-02T19:34:01.1792688Z ^[[2mdist/^[[22m^[[32mindex.html ^[[39m^[[1m^[[2m 0.39 kB^[[22m^[[1m^[[22m
test■UNKNOWN STEP■2026-10-02T19:34:01.1793710Z ^[[2mdist/^[[22m^[[2massets/^[[22m^[[35mindex-B9SJ4PVo.css ^[[39m^[[1m^[[2m248.48 kB^[[22m^[[1m^[[22m
test■UNKNOWN STEP■2026-10-02T19:34:01.1794711Z ^[[2mdist/^[[22m^[[2massets/^[[22m^[[36mindex-C2mfUB9b.js ^[[39m^[[1m^[[2m239.77 kB^[[22m^[[1m^[[22m
test■UNKNOWN STEP■2026-10-02T19:34:01.1796152Z ^[[32m✓ built in 1.13s^[[39m
test■UNKNOWN STEP■2026-10-02T19:34:01.2250383Z Post job cleanup.
test■UNKNOWN STEP■2026-10-02T19:34:01.3497573Z (node:2843) [DEP0040] DeprecationWarning: The `punycode` module is deprecated. Please use a u
test■UNKNOWN STEP■2026-10-02T19:34:01.3498917Z (Use `node --trace-deprecation ...` to show where the warning was created)
test■UNKNOWN STEP■2026-10-02T19:34:01.3741085Z [command]/usr/bin/tar --posix -cf cache.tzst --exclude cache.tzst -P -C /home/runner/work/-Tok
test■UNKNOWN STEP■2026-10-02T19:34:01.6519982Z (node:2843) [DEP0169] DeprecationWarning: `url.parse()` behavior is not standardized and prom
test■UNKNOWN STEP■2026-10-02T19:34:02.0562621Z Sent 33482556 of 33482556 (100.0%), 77.3 MBs/sec
test■UNKNOWN STEP■2026-10-02T19:34:02.1855199Z Cache saved with the key: node-cache-Linux-x64-npm-2d721bdf4658faa3da03afda4be7c748ecce65dfa6
test■UNKNOWN STEP■2026-10-02T19:34:02.2053013Z Post job cleanup.
test■UNKNOWN STEP■2026-10-02T19:34:02.2974771Z [command]/usr/bin/git version
test■UNKNOWN STEP■2026-10-02T19:34:02.3023550Z git version 2.55.0
test■UNKNOWN STEP■2026-10-02T19:34:02.3067536Z Temporarily overriding HOME='/home/runner/work/_temp/597dd9a0-bb69-4a6a-bc9c-9dcb049dd7d2' be
test■UNKNOWN STEP■2026-10-02T19:34:02.3069816Z Adding repository directory to the temporary git global config as a safe directory
test■UNKNOWN STEP■2026-10-02T19:34:02.3073936Z [command]/usr/bin/git config --global --add safe.directory /home/runner/work/-TokTickIT-/-Tok
test■UNKNOWN STEP■2026-10-02T19:34:02.3125313Z [command]/usr/bin/git config --local --name-only --get-regexp core.sshCommand
test■UNKNOWN STEP■2026-10-02T19:34:02.3172736Z [command]/usr/bin/git submodule foreach --recursive sh -c "git config --local --name-only --g
test■UNKNOWN STEP■2026-10-02T19:34:02.3441137Z [command]/usr/bin/git config --local --name-only --get-regexp http.https://github.com/\
test■UNKNOWN STEP■2026-10-02T19:34:02.3476817Z http.https://github.com/.extraheader
test■UNKNOWN STEP■2026-10-02T19:34:02.3490763Z [command]/usr/bin/git config --local --unset-all http.https://github.com/.extraheader
test■UNKNOWN STEP■2026-10-02T19:34:02.3532404Z [command]/usr/bin/git submodule foreach --recursive sh -c "git config --local --name-only --g
test■UNKNOWN STEP■2026-10-02T19:34:02.3803564Z [command]/usr/bin/git config --local --name-only --get-regexp ^includeIf\gitdir:
test■UNKNOWN STEP■2026-10-02T19:34:02.3848248Z [command]/usr/bin/git submodule foreach --recursive git config --local --show-origin --name-o
test■UNKNOWN STEP■2026-10-02T19:34:02.4256533Z Cleaning up orphan processes
test■UNKNOWN STEP■2026-10-02T19:34:02.4568026Z ##[warning]Node.js 20 is deprecated. The following actions target Node.js 20 but are being fo
```

Rendered passing output: final-main-server-ci.log

Rendered passing output: final-main-e2e-ci.log

Answer Part 4: AI Use with Reflection

Full ai-use.md

Rendered ai-use.md - LLM and selected prompts

The source records the actual AI workflow and selected prompts; wording is preserved from the repository.

Lab 3 AI Use and Student Reflection

Prepared 2026-09-15 and updated 2026-10-03. Lab 3 final release is on main at d152bc10d4fe146e59304d9d09343f81295429ad; exact-final-main Client/Server/E2E CI is green. PR #86 carries the reviewed responsive/final-submission evidence and PR #87 promotes that staging state to final main. Earlier implementation used the Codex desktop coding agent where the exact model identifier was not exposed. The final evidence pass also used ChatGPT GPT-5.6 Sol. No AI-generated peer approval or human visual sign-off is claimed.

Actual selected prompts so far

The following are 10 excerpts of real user prompts from this task, not invented examples. Keep the list within the handout's 6-10 prompt requirement; add a later prompt only if an earlier item is replaced.

1. ■■■■■ Lab sheet ■■■■■ ... ■■■■■ ... — requested thorough reading only; the agent read all 18 pages, text, tables and sample images and did not implement document instructions.
2. STEP ■■■■■ — requested the first step; the agent identified inspecting Lab 2 and preparing specification/API/UI/test contract before coding.
3. ... ■■■■■ Engineering Contract ■■■■ Lab3 + add commit ... ■■■■■ push ... ■■■■ ... ■■■■■ ... title , descript ■■■■ issue ■■■■■ ... — authorized repository inspection, contract/Issue plan/documentation and local staging/commit; prohibited push and reserved Issue creation to the user.
4. ■■■■ issue ... ■■■■■ 17 ■■■■ ■■■■ title ■■■■ descript + add ■■■■■ project ... push feature/24-lab3-engineering-contract ... ■■■■ PR — authorized the real Issue/Project/branch/PR workflow after the earlier no-push boundary was explicitly changed.
5. ■■■■■ feedback PR #68 — directed the agent to reconcile logout semantics, staging linkage, terminal ownership, scope, script benchmarking, release evidence and exact paths across the contract.
6. ■■■■ push ■■■■■ ... ■■■■■ Repo ■■■■■ ■■■■ push — directed recovery of the developer-written reviewer identity and Reflection from the wrong repository and transfer to this PR only.
7. Initial-password session expiry ■■■■ ambiguous ... Password-change + session rotation ... atomic ... ■■■■ manual unassign — required fixed restricted-session boundaries, atomic credential/session rotation and a deliberate scope decision before implementation.
8. Issue #62 ... ■■■■■ Unassign; Issue #61 ... ■■■■■ unique-key/replay wording — required the implementation handoff and live Issues to match the already revised normative contract.
9. PR ■■■■■ Lab sheet + ■■■■ issue ■■■■■ — started the implementation sequence after the staging PR merge, leading to Issues #52-#55 and their review/CI evidence.
10. ■■■■■ feedback ... PR #70/#71/#72 — directed implementation agents to fix concrete CI/reviewer findings, including role-scoped fixtures, migration evidence, session/API security, authorization and authenticated regression tests.

How AI was used in this stage

The agent inspected actual Prisma/models/migrations, server/frontend APIs/screens, tests/Playwright/CI and Lab 2 documentation; consulted relevant prior task messages as supporting context; resolved exact data/API/authorization/workflow/provisioning decisions and mapped 32 ACs to planned tests. External security references are linked in specification.md. Other students' repositories/PRs were not used as this project's baseline or implementation; the L0u1sss repository was read only to recover the two developer-authored documentation edits that had been pushed there by mistake.

Document validation/staging/commit are separate from product completion. PRs #68-#82 now cover the merged Lab 3 implementation line on lab3-staging, including authentication, Requester, Staff workflow/conversations, and Administrator User Management. Issue #65 is intentionally still open because release acceptance includes lab3-staging -> main, exact-final-main reruns, RELEASE-01 evidence, responsive/accessibility/visual records, and the single Part 1-9 PDF. The student must keep the final My Reflection in their own voice and record later prompts/settings accurately.

My Reflection (student-authored source)

This section is rendered from the existing repository file; it is not newly fabricated for this PDF.

My Reflection

■ Lab 3 ■ AI Agent ■ labsheet ■ requirements ■ specification, API, UI ■ test plan ■
 ■
 ■ AI ■ Human-in-the-loop
 ■ peer
 review ■ Lab 3 labsheet ■

Answer Part 5: Working Login and Password Change UI

Evidence coverage: valid/invalid credentials, inactive-account handling, safe failures/rate limits, mandatory first-password change, authenticated user/role display, logout and blocked direct access are covered by authentication E2E/API/UI tests. The large UI capture below demonstrates the Zen Green login surface; detailed state behavior is traceable in tests.md and authentication.spec.ts.

[authentication.spec.ts](#)

Part 5 UI Evidence - Login (desktop)

TOKTICKIT - SECURE ACCESS

Sign in

Use the account provided by your administrator.

Email

Password

[Show password](#)

Sign In

1440px desktop login. Enlarged as a single image so fields, labels, button and validation area remain readable.

Answer Part 6: Working IT Staff Ticket Queue UI

Queue evidence covers realistic seeded Tickets, search, filters, sorting, pagination, assigned/unassigned ownership, status/priority badges, detail navigation, empty/no-results/failure feedback and responsive behavior.

[staff-queue.spec.ts](#)

Part 6 UI Evidence - Staff Queue (desktop)

TokTickIT

Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

SHARED IT WORKSPACE

Ticket Queue

Shared work for IT Staff and Administrators. Filters apply across every Ticket.

Search and filters

Ticket Number/Summary search

Category

Related System

Requested Priority

IT Priority

Status

Owner

Ticket number or summary

All Categories

All Systems

All Requested Priorities

All IT Priorities

All Statuses

All

Sort and page size

Sort by

Direction

Page size

Clear Filters

Last updated

Descending

10

49 matching Tickets

Ticket Number	Summary	Category	Requested Priority	IT Priority	Status	Owner	Open
TKT-2026-900011	Seeded Lab 3 Ticket 11 Requester: Anan Srisuk	Software	HIGH	MEDIUM	IN PROGRESS	Unassigned	Open
TKT-2026-900049	Feature 22 visual evidence 1791023772178-b9ba5540 Requester: Anan Srisuk	Account and Access	HIGH	HIGH	NEW	Unassigned	Open
TKT-2026-900048	Feature 22 visual evidence 1791023770835-9be58545 Requester: Anan Srisuk	Account and Access	HIGH	HIGH	NEW	Unassigned	Open
TKT-2026-900047	Feature 22 visual evidence 1791023769471-7a76cb33 Requester: Anan Srisuk	Account and Access	HIGH	HIGH	NEW	Unassigned	Open
TKT-2026-900046	Feature 22 success 1791023765326 Requester: Anan Srisuk	Account and Access	HIGH	HIGH	NEW	Unassigned	Open
TKT-2026-900045	Feature 22 visual evidence 1791023764011-1a5a2088 Requester: Anan Srisuk	Account and Access	HIGH	HIGH	NEW	Unassigned	Open

Top operational queue region at 1440px.

Answer Part 7: Working IT Staff Ticket Detail UI

Staff Detail evidence covers claim/reassign, IT Priority, permitted status transitions, Public Comments, restricted Internal Notes, Attachment continuity, Requester resolution indication, role restrictions, validation/conflict handling and safe failures. Direct authorization suites verify Requesters cannot retrieve Internal Notes or infer protected-resource existence.

[staff-ticket-flow.spec.ts](#)

[authorization.api.test.ts](#)

Part 7 UI Evidence - Staff Ticket Detail (top)

TokTickIT Ticket Queue

E2E Staff · IT StaffChange PasswordLogout

[<- Back to Queue](#)

SHARED IT WORKSPACE

TKT-2026-900011

IN PROGRESS

Operational Ticket Detail - version 1

Submitted Ticket Information
Requester-submitted values are read-only.

Ticket Number
TKT-2026-900011

Requester
Anan Srisuk (anan.srisuk@example.test)

Related System
LEB2 App

Summary
Seeded Lab 3 Ticket 11

Description
Synthetic local-lab workflow fixture. No sensitive information.

Ticket Date
Oct 3, 2026, 10:35 AM

Category
Software

Requested Priority
HIGH

Operational Controls
Each save uses loaded version 1. Only one operational save can run at a time.

Ticket Owner
Current owner: **Unassigned**

Eligible owner
Select an eligible owner

Claim Ticket

Assign Owner

IT Priority
Requested Priority: **HIGH**

IT Priority
MEDIUM

Save IT Priority

Status Workflow
Current status: **IN PROGRESS**

Next status
Choose next status

Change Status

Ticket identity, requester context and operational controls.

Part 7 UI Evidence - Staff Ticket Detail (lower)

Resolution and Requester Indication

Requester indication
Not indicated

Resolved at
Not recorded

Closed at
Not recorded

Attachments

Staff can download active Requester Attachments. Upload and removal remain Requester actions.

staff-e2e.pdf

ACTIVE application/pdf 72 B Uploaded Oct 3, 2026, 10:36 AM

Download staff-e2e.pdf

Public Comments

Visible to the Requester

Anan Srisuk **REQUESTER** Oct 3, 2026, 10:35 AM

Public fixture comment for TKT-2026-900011.

Public Comment

0/5,000 characters. Content is shown as plain text.

Post Public Comment

Internal Notes

Internal Note - visible only to IT Staff and Administrators

Support Three **IT STAFF** Oct 3, 2026, 10:35 AM

Internal fixture note for TKT-2026-900011.

Internal Note

0/5,000 characters. Content is shown as plain text.

Save Internal Note

Lower detail region including conversation/notes evidence.

Answer Part 8: Working Administrator User Management UI

Admin evidence covers Name/Email/Role/Status/Edit list, search, optional role filter, create with one role and initial password, duplicate/invalid validation, edit name/email/role/activation, reset initial password, self-deactivation protection, last-active-Administrator protection, forbidden non-Admin access, responsive Zen Green layout and safe failure feedback.

[admin-user-management.spec.ts](#)

Part 8 UI Evidence - Administrator User Management

TokTickIT

User ManagementTicket Queue

E2E Administrator · Administrator

Change PasswordLogout

ADMINISTRATOR WORKSPACE

Create User

User Management

Create and maintain one-role accounts. Deactivate accounts instead of deleting them.

Search name or email

Role

All Roles

Name	Email	Role	Status	Action
Anan Srisuk	anan.srisuk@example.test	Requester	Active	Edit Anan Srisuk
Benjamas Kittipong	benjamas.kittipong@example.test	Requester	Active	Edit Benjamas Kittipong
Chaiwat Somchai	chaiwat.somchai@example.test	Requester	Active	Edit Chaiwat Somchai
Daranee Ploy	daranee.ploy@example.test	Requester	Active	Edit Daranee Ploy
E2E Administrator	e2e.admin@example.test	Administrator	Active	Edit E2E Administrator
E2E Auth Requester	e2e.auth.requester@example.test	Requester	Active	Edit E2E Auth Requester
E2E Boundary Requester	e2e.boundary.requester@example.test	Requester	Active	Edit E2E Boundary Requester
E2E Normal Expiry Requester	e2e.normal-expiry.requester@example.test	Requester	Active	Edit E2E Normal Expiry Requester
E2E Staff	e2e.staff@example.test	IT Staff	Active	Edit E2E Staff
Inactive Requester	inactive.requester@example.test	Requester	Inactive	Edit Inactive Requester
Inactive Support	inactive.support@example.test	IT Staff	Inactive	Edit Inactive Support
Support One	support.one@example.test	IT Staff	Active	Edit Support One
Support Three	support.three@example.test	IT Staff	Active	Edit Support Three
Support Two	support.two@example.test	IT Staff	Active	Edit Support Two
TokTickIT Administrator	admin@example.test	Administrator	Active	Edit TokTickIT Administrator

1440px Administrator User Management. The image is displayed large enough to read columns, role/status badges and actions.

Answer Part 9: Zen Green UI and Responsive Evidence

[Full ui-spec.md](#)

Rendered ui-spec.md - Zen Green contract

Rendered grading-relevant visual/accessibility rules from the repository source.

Lab 3 Zen Green UI Specification

Version 1.0, prepared 2026-09-15 for review. specification.md (specification.md) and api-spec.md (api-spec.md) define access and data behavior. New UI is planned; no screenshots or passing visual checks are claimed here.

1. Existing design foundation

Reuse the Lab 2 tokens in client/src/App.css and docs/lab-02/ui-spec.md: primary #006B3C, secondary #0B7A46, pale #EAF6EF, page #F5F7F6, surface #FFFFFF, text #173B2C, muted #52685E, border #C9D6CF, readonly #EFF3F0, error #9B1C1C, warning #9A6700/#FFF4CE and focus #0B7A46. Keep the Inter/Segoe UI/system font stack, 16px body, at least 14px metadata, 4/8/12/16/24/32/48px spacing, 8-12px cards, 6-8px controls and practical 44px touch targets. Verify actual contrast, rather than assuming token names guarantee accessibility.

Extract reusable Shell, Field, Button, Badge, Feedback, Dialog, Pagination, AttachmentSection and Ticket information groups from the current single-file App.tsx where needed. Proposed module names are organizational choices, not a requirement to rewrite all existing code. Share styling/components across roles; keep authorization in backend middleware/services as well as screen guards.

2. Routes, shell and session behavior

Proposed browser routes (use the existing navigation mechanism or a small router; ensure refresh/back/direct routes work):

Route	Permitted session	Main mode/default destination
---	---	---
/login	public	sign in
/change-password	authenticated, including initial-password	mandatory or voluntary password change
/requester/tickets	normal Requester	owned list/default Requester landing
/requester/tickets/new	normal Requester	create
/requester/tickets/:id	normal Requester	read-only Ticket with permitted actions
/staff/tickets	normal IT Staff/Administrator	shared queue/default IT Staff landing
/staff/tickets/:id	normal IT Staff/Administrator	operational detail
/admin/users	normal Administrator	list/create/edit/default Administrator landing

- At startup GET /auth/me; while pending show a labelled loading surface without cached protected content. No session -> Login. mustChangePassword -> Change Password before any normal screen/navigation.

- Header retains TokTickIT branding, accessible active navigation and current name/role. Requester navigation: My Tickets/Create Ticket. IT Staff: Ticket Queue. Administrator: User Management/Ticket Queue, reflecting its explicit matrix permission.

- User menu provides Change Password and Logout. Restricted sessions expose only Change Password and Logout. A restricted session expires exactly 15 minutes after login regardless of activity; the client may show remaining time for feedback but cannot extend it. At expiry, clear protected state and return to Login after the API's 401. No Development Requester selector, Change Requester or persisted requester identity.

- Refresh retrieves me/CSRF; all API fetches use credentials=include. Clear Ticket/user/draft/list account state on logout, reauthenticationRequired, revoked session or account switch via a new login; abort/discard old pending responses so they cannot populate another account's UI.

- Wrong-role direct route: Forbidden with a link to the permitted landing screen and no protected data. Missing/non-owned Ticket: identical Not Found. 401 -> clear protected state and Login; initial-password 403 -> mandatory screen.

- Logout is busy until the empty 204 response, including repeated/expired-session attempts; then clear local auth state and return to Login. For an active session, invalid CSRF/Origin returns 403 without deleting it. If logout fails through network/500, keep session state and show Retry so UI does not claim server invalidation that has not occurred.

3. Main screen modes and common feedback

Mode describes the screen's purpose, not a separate formal state for every error.

Screen	Modes	Required feedback
---	---	---
Login	sign in	field validation; signing in; generic credential failure/inactive handling; rate limit; safe network/server failure
Change Password	mandatory/voluntary	policy/current/confirmation errors; saving; success; session expiration; safe failure

| My Tickets | list | loading; empty; no results; invalid-query reset; safe failure |

| Create Ticket | create/saved confirmation | loading references; validation; submitting; Ticket success; per-file partial failure/retry |

| Requester detail | view plus Attachment/comment/indication actions | loading/not-found; busy; validation; comment empty; safe failure/conf

| Ticket Queue | list | loading; empty; no results; forbidden; invalid query; safe failure |

| Staff detail | view/operational field edit | loading/not-found/forbidden; saving; conflict/refresh; comment/note empty; validation; safe fa

| User Management | list/create/edit/reset | loading; empty/no results; saving; duplicate email; admin-safety/stale conflict; validation; su

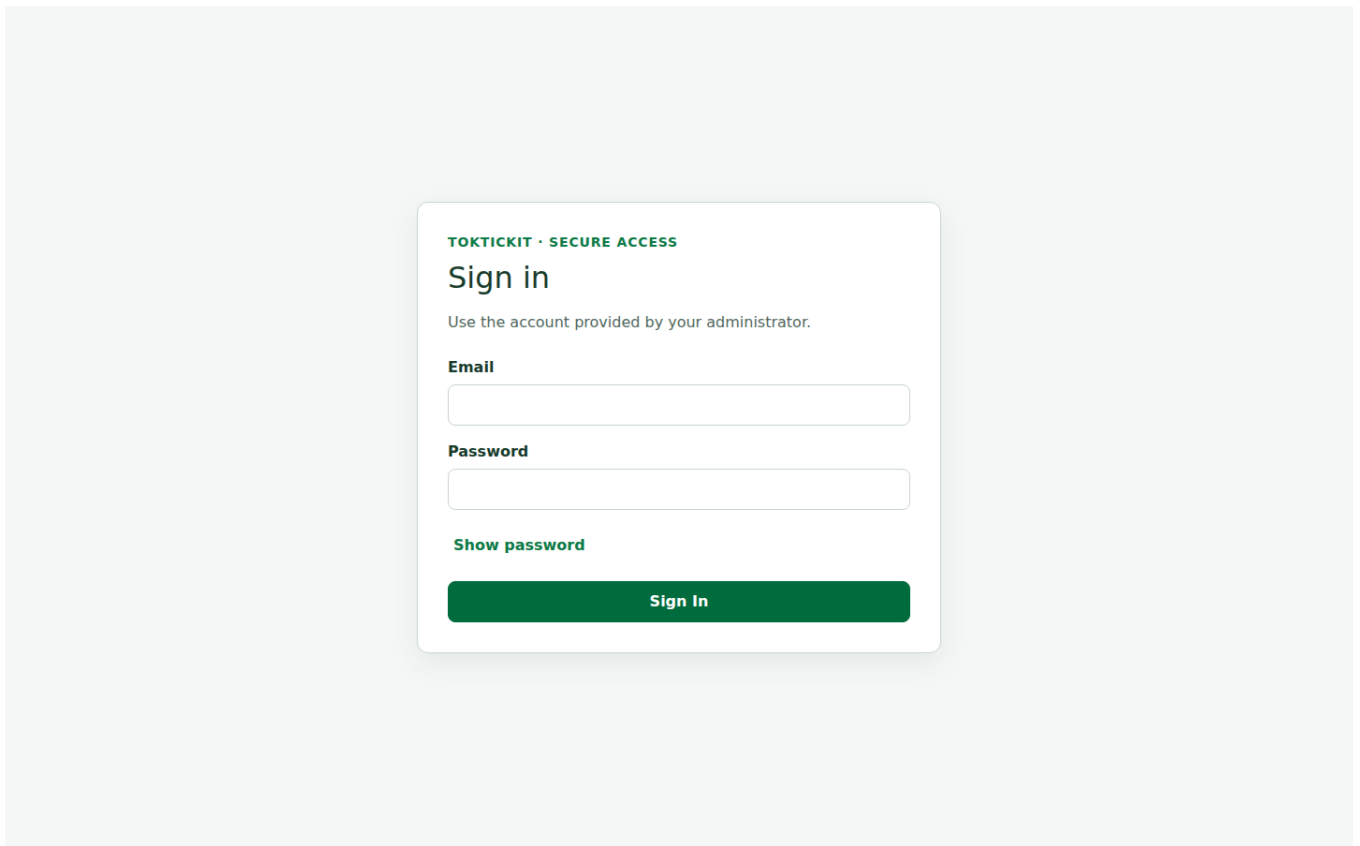
Use inline labelled alerts near affected actions, aria-live for async status, aria-busy while processing and disabled repeat controls. Preserve non-secret drafts/filters after safe failure. Clear password controls on credential failure/success and when leaving a credential form. Move invalid submit focus to the first invalid field. Conflict messaging explains refresh/review; do not silently overwrite concurrent changes.

Completed evidence checklist

Checklist	Status	Evidence
Design consistency	PASS	Zen Green tokens/shell used across Login, Requester, Staff and Admin captures.
Role navigation	PASS	Role-specific screens/navigation are covered by UI/E2E authorization evidence.
Badges	PASS	Status, Requested Priority, IT Priority and role presentation are visible/covered.
Editable vs read-only fields	PASS	UI contract and Staff/Admin captures preserve distinct operational/editable controls.
Validation placement	PASS	UI tests cover validation/safe failure placement; no layout regression reported in final evidence run.
Focus / keyboard behavior	PASS - automated evidence	Dialog/keyboard and accessibility-focused tests are recorded in tests.md; this label does not invent a separate human sign-off.
Clipping / overlap	PASS	Final responsive capture suite found and fixed real 768 Requester and 360 Admin overflow defects before rerun.
Horizontal overflow	PASS	Final responsive suite asserts no document-level horizontal overflow at required evidence widths.
Secret/Internal Note leakage	PASS	Peer review of PR #86 opened screenshots and confirmed no secret leakage; API authorization tests protect Internal Notes.

Note: this checklist reports evidence supported by tests, screenshots and peer-review records. It does not falsely claim that an AI is a human accessibility reviewer.

Part 9 - Desktop 1440px: Login



The screenshot shows a login form for TokTickIT. The form is centered on a light gray background. It has a white background with rounded corners and a subtle shadow. The form contains the following elements:

- TOKTICKIT · SECURE ACCESS**: A header in green text.
- Sign in**: A large heading in black text.
- Use the account provided by your administrator.**: A sub-header in gray text.
- Email**: A label in bold black text above a text input field.
- Password**: A label in bold black text above a text input field.
- Show password**: A link in green text below the password field.
- Sign In**: A green button with white text at the bottom of the form.

Desktop 1440px evidence for Login. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/1440/.

Part 9 - Desktop 1440px: Requester My Tickets

TokTickIT **My Tickets** **Create Ticket**

Anan Srisuk · Requester

Change Password

Logout

REQUESTER WORKSPACE

My Tickets

Create Ticket

Tickets created by Anan Srisuk.

Search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

All Priorities

Current Status

All Statuses

Sort by

Last updated

Direction

Newest first

Page size

10

Showing 10 of 28 Tickets

Ticket Number	Summary	Category	Related System	Requested Priority	Current Status	Last Updated	
TKT-2026-900011	Seeded Lab 3 Ticket 11	Software	LEB2 App	HIGH	IN_PROGRESS	Oct 3, 2026, 10:36 AM	View Ticket
TKT-2026-900049	Feature 22 visual evidence 1791023772178-b9ba5540	Account and Access	Campus Wi-Fi	HIGH	NEW	Oct 3, 2026, 10:36 AM	View Ticket
TKT-2026-900048	Feature 22 visual evidence 1791023770835-9be58545	Account and Access	Campus Wi-Fi	HIGH	NEW	Oct 3, 2026, 10:36 AM	View Ticket
TKT-2026-	Feature 22 visual evidence	Account	Campus	HIGH	NEW	Oct 3,	View Ticket

Desktop 1440px evidence for Requester My Tickets. Shown as a readable viewport crop; full original capture remains in [artifacts/lab-03/screenshots/1440/](#).

Part 9 - Desktop 1440px: Staff Queue

TokTickIT Ticket Queue

E2E Staff · IT Staff Change Password Logout

SHARED IT WORKSPACE

Ticket Queue

Shared work for IT Staff and Administrators. Filters apply across every Ticket.

Search and filters

Ticket Number/Summary search

Category

Related System

Requested Priority

IT Priority

Status

Owner

Ticket number or summary

All Categories

All Systems

All Requested Priorities

All IT Priorities

All Statuses

All

Sort and page size

Sort by

Direction

Page size

Clear Filters

Last updated

Descending

10

49 matching Tickets

Ticket Number	Summary	Category	Requested Priority	IT Priority	Status	Owner	Open
TKT-2026-900011	Seeded Lab 3 Ticket 11 Requester: Anan Srisuk	Software	HIGH	MEDIUM	IN PROGRESS	Unassigned	<button>Open</button>
TKT-2026-	Feature 22 visual evidence	Account and	HIGH	HIGH	NEW	Unassigned	<button>Open</button>

Desktop 1440px evidence for Staff Queue. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/1440/.

TokTickIT Lab 3 - Final Submission Evidence

Page 33

Part 9 - Desktop 1440px: Staff Ticket Detail

TokTickIT Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

[<- Back to Queue](#)

SHARED IT WORKSPACE

TKT-2026-900011

IN PROGRESS

Operational Ticket Detail - version 1

Submitted Ticket Information
Requester-submitted values are read-only.

Ticket Number
TKT-2026-900011

Requester
Anan Srisuk (anan.srisuk@example.test)

Related System
LEB2 App

Summary
Seeded Lab 3 Ticket 11

Description
Synthetic local-lab workflow fixture. No sensitive information.

Ticket Date
Oct 3, 2026, 10:35 AM

Category
Software

Requested Priority
HIGH

Operational Controls
Each save uses loaded version 1. Only one operational save can run at a time.

Ticket Queue

IT Details

Desktop 1440px evidence for Staff Ticket Detail. Shown as a readable viewport crop; full original capture remains in [artifacts/lab-03/screenshots/1440/](#).

Part 9 - Desktop 1440px: Administrator User Management

TokTickIT **User Management** **Ticket Queue**

E2E Administrator · Administrator

Change Password

Logout

ADMINISTRATOR WORKSPACE

Create User

Search name or email

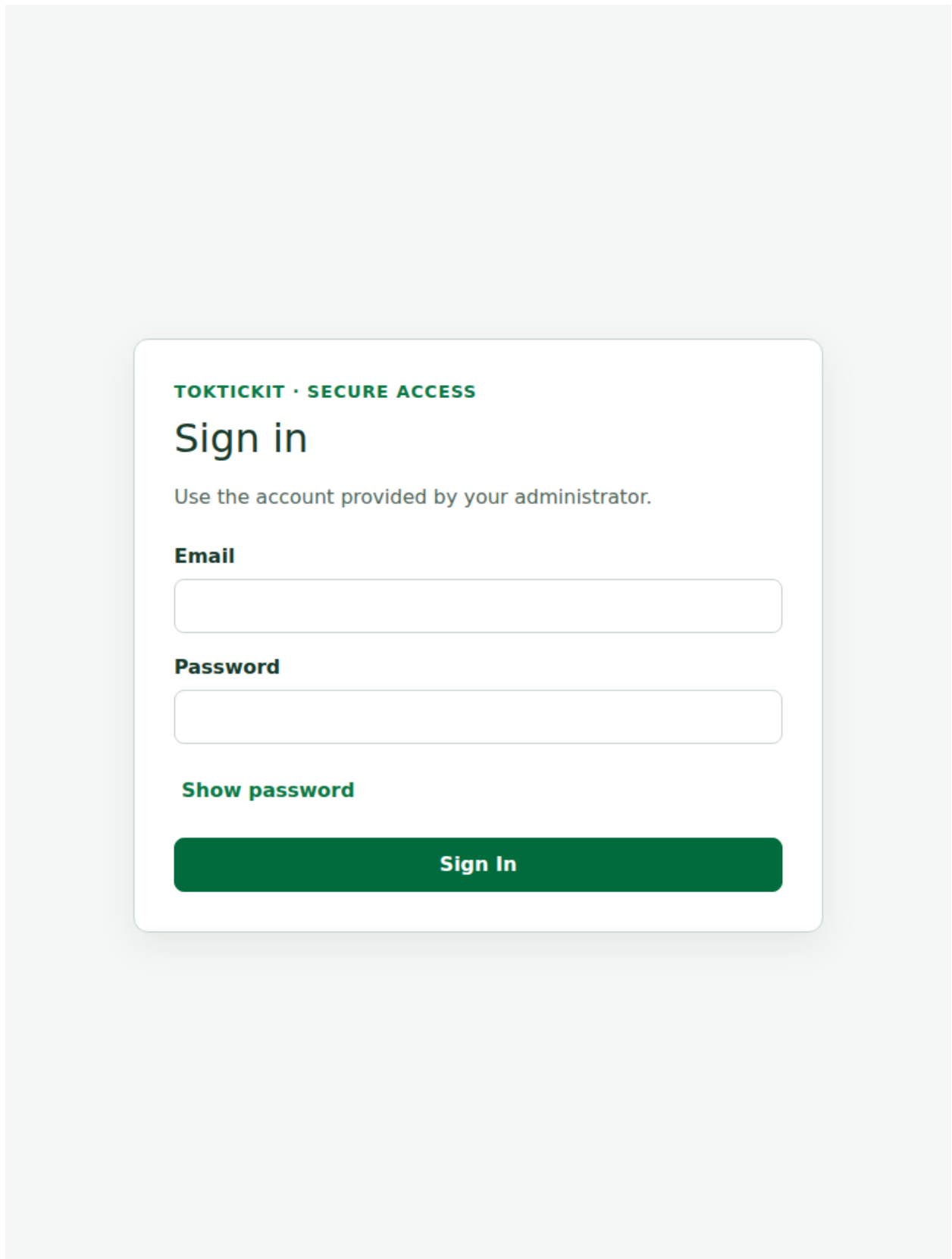
Role

All Roles

Name	Email	Role	Status	Action
Anan Srisuk	anan.srisuk@example.test	Requester	Active	Edit Anan Srisuk
Benjamas Kittipong	benjamas.kittipong@example.test	Requester	Active	Edit Benjamas Kittipong
Chaiwat Somchai	chaiwat.somchai@example.test	Requester	Active	Edit Chaiwat Somchai
Daranee Ploy	daranee.ploy@example.test	Requester	Active	Edit Daranee Ploy
E2E Administrator	e2e.admin@example.test	Administrator	Active	Edit E2E Administrator
E2E Auth Requester	e2e.auth.requester@example.test	Requester	Active	Edit E2E Auth Requester
E2E Boundary Requester	e2e.boundary.requester@example.test	Requester	Active	Edit E2E Boundary Requester

Desktop 1440px evidence for Administrator User Management. Shown as a readable viewport crop; full original capture remains in [artifacts/lab-03/screenshots/1440/](#).

Part 9 - Tablet 768px: Login

A screenshot of a login form on a tablet screen. The form is white with rounded corners and a subtle shadow, centered on a light gray background. At the top, it says 'TOKTICKIT • SECURE ACCESS' in green. Below that is the title 'Sign in' in a large, dark font. A line of text reads 'Use the account provided by your administrator.' in a smaller, gray font. There are two input fields: one for 'Email' and one for 'Password', both with light gray borders. Below the password field is a green link that says 'Show password'. At the bottom is a large, dark green button with the text 'Sign In' in white.

TOKTICKIT • SECURE ACCESS

Sign in

Use the account provided by your administrator.

Email

Password

Show password

Sign In

Tablet 768px evidence for Login. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/768/.

Part 9 - Tablet 768px: Requester My Tickets

TokTickIT My Tickets Create Ticket

Anan Srisuk · RequesterChange PasswordLogout

REQUESTER WORKSPACE

My Tickets

Create Ticket

Tickets created by Anan Srisuk.

Search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

All Priorities

Current Status

All Statuses

Sort by

Last updated

Direction

Newest first

Page size

10

Showing 10 of 28 Tickets

TKT-2026-900011

Summary	Seeded Lab 3 Ticket 11
Category	Software
Related System	LEB2 App
Requested Priority	HIGH
Current Status	IN_PROGRESS
Last Updated	Oct 3, 2026, 10:36 AM

Tablet 768px evidence for Requester My Tickets. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/768/.

Part 9 - Tablet 768px: Staff Queue

TokTickIT Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

SHARED IT WORKSPACE

Ticket Queue

Shared work for IT Staff and Administrators. Filters apply across every Ticket.

Search and filters

Ticket Number/Summary search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

All Requested Priorities

IT Priority

All IT Priorities

Status

All Statuses

Owner

All

Sort and page size

Sort by

Last updated

Direction

Descending

Page size

10

Clear Filters

49 matching Tickets

TKT-2026-900011

Seeded Lab 3 Ticket 11

Requester: Anan Srisuk

Category

Software

Tablet 768px evidence for Staff Queue. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/768/.

TokTickIT Lab 3 - Final Submission Evidence

Page 38

Part 9 - Tablet 768px: Staff Ticket Detail

TokTickIT

Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

[<- Back to Queue](#)

SHARED IT WORKSPACE

TKT-2026-900011

IN PROGRESS

Operational Ticket Detail - version 1

Submitted Ticket Information

Requester-submitted values are read-only.

Ticket Number

TKT-2026-900011

Ticket Date

Oct 3, 2026, 10:35 AM

Requester

Anan Srisuk (anan.srisuk@example.test)

Category

Software

Related System

LEB2 App

Requested Priority

HIGH

Summary

Seeded Lab 3 Ticket 11

Description

Synthetic local-lab workflow fixture. No sensitive information.

Operational Controls

Each save uses loaded version 1. Only one operational save can run at a time.

Ticket Owner

Current owner: Unassigned

Eligible owner

Select an eligible owner

IT Priority

Requested Priority: HIGH

IT Priority

MEDIUM

Tablet 768px evidence for Staff Ticket Detail. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/768/.

Part 9 - Tablet 768px: Administrator User Management

TokTickIT User Management Ticket Queue

E2E Administrator · AdministratorChange PasswordLogout

ADMINISTRATOR WORKSPACE

Create User

User Management

Create and maintain one-role accounts. Deactivate accounts instead of deleting them.

Search name or email

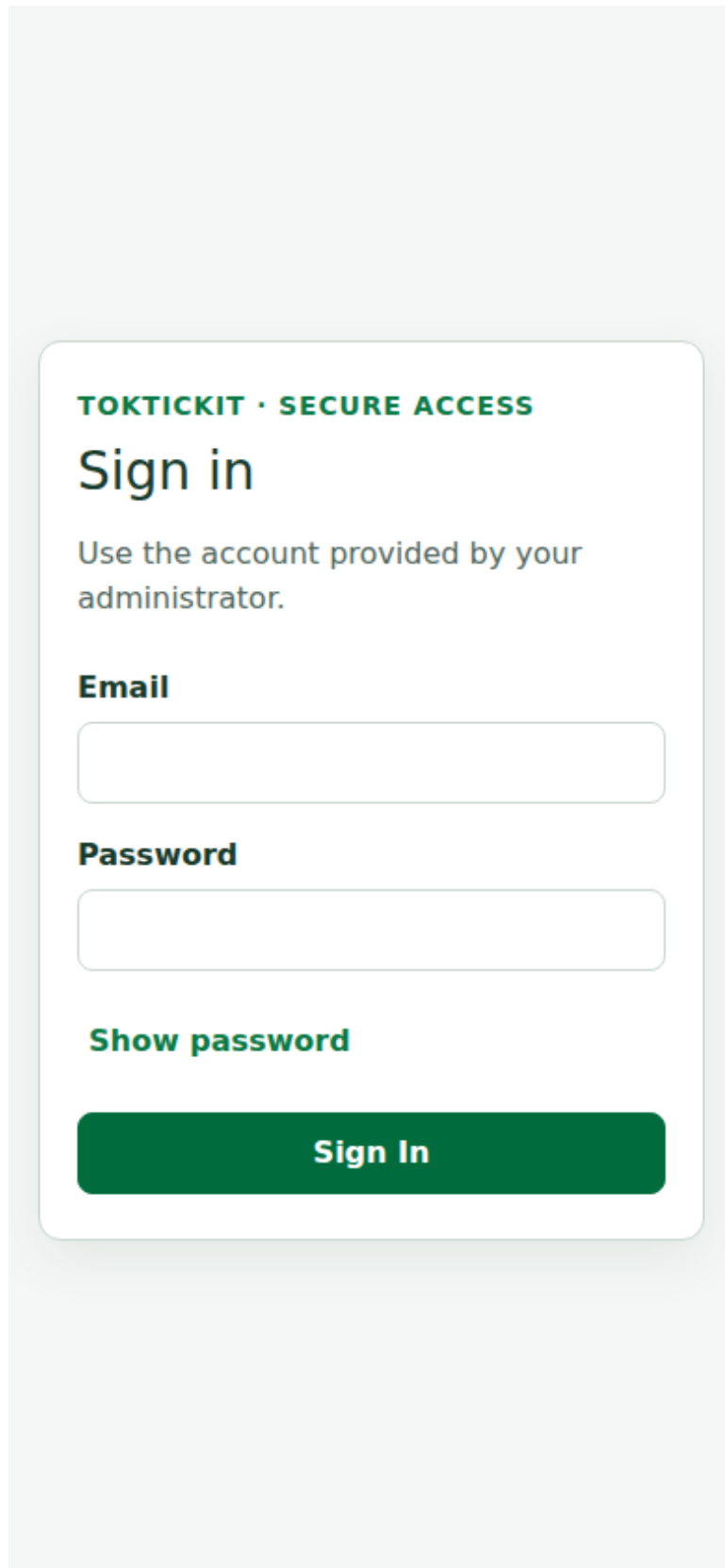
Role

All Roles

Name	Email	Role	Status
Anan Srisuk	anan.srisuk@example.test	Requester	Active
Benjamas Kittipong	benjamas.kittipong@example.test	Requester	Active
Chaiwat Somchai	chaiwat.somchai@example.test	Requester	Active
Daranee Ploy	daranee.ploy@example.test	Requester	Active
E2E Administrator	e2e.admin@example.test	Administrator	Active
E2E Auth Requester	e2e.auth.requester@example.test	Requester	Active
E2E Boundary Requester	e2e.boundary.requester@example.test	Requester	Active

Tablet 768px evidence for Administrator User Management. Shown as a readable viewport crop; full original capture remains in [artifacts/lab-03/screenshots/768/](#).

Part 9 - Mobile 390px: Login

A screenshot of a mobile login form for TokTickIT. The form is centered on a light gray background. It features a white card with rounded corners containing the following elements: a header "TOKTICKIT · SECURE ACCESS" in green, a large "Sign in" title, a subtitle "Use the account provided by your administrator.", an "Email" label above a text input field, a "Password" label above another text input field, a "Show password" link in green, and a green "Sign In" button at the bottom.

TOKTICKIT · SECURE ACCESS

Sign in

Use the account provided by your administrator.

Email

Password

Show password

Sign In

Mobile 390px evidence for Login. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/390/.

Part 9 - Mobile 390px: Requester My Tickets

TokTickIT

My Tickets **Create Ticket**

Anan Srisuk · Requester

Change Password

Logout

REQUESTER WORKSPACE

My Tickets

Tickets created by Anan Srisuk.

Create Ticket

Search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

All Priorities

Current Status

Mobile 390px evidence for Requester My Tickets. Shown as a readable viewport crop; full original capture remains in [artifacts/lab-03/screenshots/390/](#).

Part 9 - Mobile 390px: Staff Queue

TokTickIT

Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

SHARED IT WORKSPACE

Ticket Queue

Shared work for IT Staff and Administrators.
Filters apply across every Ticket.

Search and filters

Ticket Number/Summary search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

All Requested Priorities

IT Priority

Mobile 390px evidence for Staff Queue. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/390/.

Part 9 - Mobile 390px: Staff Ticket Detail

TokTickIT

Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

[<- Back to Queue](#)

SHARED IT WORKSPACE
TKT-2026-900011
Operational Ticket Detail - version 1

IN PROGRESS

Submitted Ticket Information

Requester-submitted values are read-only.

Ticket Number
TKT-2026-900011

Ticket Date
Oct 3, 2026, 10:35 AM

Requester
Anan Srisuk
(anan.srisuk@example.test)

Mobile 390px evidence for Staff Ticket Detail. Shown as a readable viewport crop; full original capture remains in artifacts/lab-03/screenshots/390/.

Part 9 - Mobile 390px: Administrator User Management

TokTickIT

User Management **Ticket Queue**

E2E Administrator · Administrator

Change Password

Logout

ADMINISTRATOR WORKSPACE

User Management

Create and maintain one-role accounts.
Deactivate accounts instead of deleting them.

Create User

Search name or email

Role

All Roles ▾

Anan Srisuk

anan.srisuk@example.test

Role: Requester

Mobile 390px evidence for Administrator User Management. Shown as a readable viewport crop; full original capture remains in [artifacts/lab-03/screenshots/390/](#).

Part 9 - Narrow mobile 360px: Staff Queue

TokTickIT

Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

SHARED IT WORKSPACE

Ticket Queue

Shared work for IT Staff and Administrators. Filters apply across every Ticket.

Search and filters

Ticket Number/Summary search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

Additional Narrow mobile 360px evidence. Original full-page capture is preserved in the repository.

Part 9 - Narrow mobile 360px: Administrator User Management

TokTickIT

User Management **Ticket Queue**

E2E Administrator · Administrator

Change Password

Logout

ADMINISTRATOR WORKSPACE

User Management

Create and maintain one-role accounts.
Deactivate accounts instead of deleting them.

Create User

Search name or email

Role

All Roles ▾

Anan Srisuk

anan.srisuk@example.test

Additional Narrow mobile 360px evidence. Original full-page capture is preserved in the repository.

TokTickIT Ticket Queue

E2E Staff · IT Staff

Change Password

Logout

SHARED IT WORKSPACE

Ticket Queue

Shared work for IT Staff and Administrators. Filters apply across every Ticket.

Search and filters

Ticket Number/Summary search

Ticket number or summary

Category

All Categories

Related System

All Systems

Requested Priority

All Requested Priorities

IT Priority

All IT Priorities

Status

All Statuses

Owner

All

Sort and page size

Sort by

Last updated

Direction

Descending

Page size

10

Clear Filters

49 matching Tickets

Additional 200% zoom-equivalent evidence. Original full-page capture is preserved in the repository.

TokTickIT Lab 3 - Final Submission Evidence

Page 48

TokTickIT

User ManagementTicket Queue

E2E Administrator · Administrator

Change PasswordLogout

ADMINISTRATOR WORKSPACE

Create User

User Management

Create and maintain one-role accounts. Deactivate accounts instead of deleting them.

Search name or email

Role

All Roles

Anan Srisuk

anan.srisuk@example.test

Role: Requester

Status: Active

Edit Anan Srisuk

Benjamas Kittipong

Additional 200% zoom-equivalent evidence. Original full-page capture is preserved in the repository.

Final Verification

Released main verified before this evidence-only PDF update: 319c34c3d23a86fa6a28ef74d7f9d8e11f1a6de6. Post-merge CI: Client 37136334077 SUCCESS, Server 37136334040 SUCCESS, E2E 37136334094 SUCCESS. Issue #65 and PR #89 were verified Done in the GitHub Project.

The repository and final main branch remain the source of truth. This PDF intentionally renders the grading-relevant portions of specification.md, tests.md, ai-use.md, reviewer.md and ui-spec.md and links to the complete files.